Mettere in sicurezza ambienti SQL Server

Gianluca Hotz

ghotz@ugiss.org | @glhotz

Sponsors

altitudo

APRA
a vargroup company

PluService.net
Sistemi Informativi Integrati
per la Mobilità

Dev>Marche

Università Politecnica delle Marche

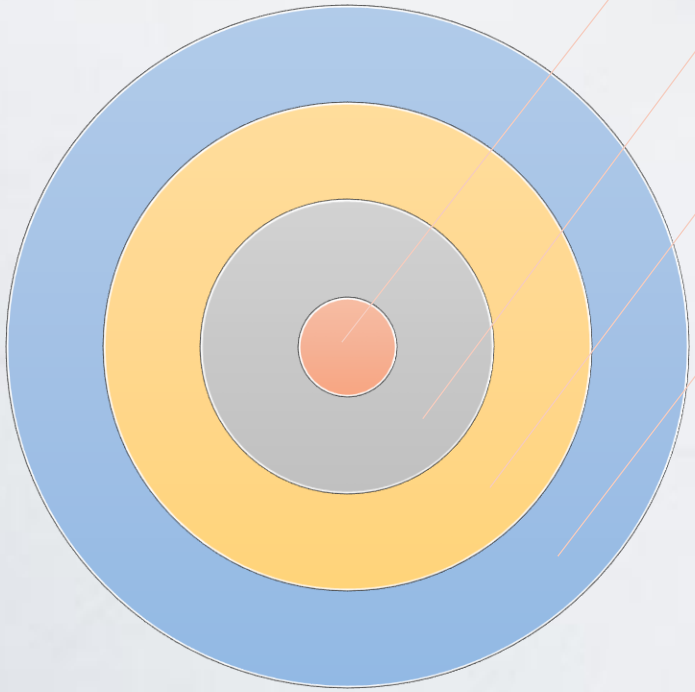
UGISS

Microsoft

Who am I?

- Gianluca Hotz | @glhotz | ghotz@ugiss.org
- Independent Consultant, Founder and Mentor SolidQ
  - 20+ years on SQL Server (from 4.21 in 1996)
  - Database modeling and development, sizing and administration, upgrade and migration, performance tuning
- Interests
  - Relational model, DBMS architecture, Security, High Availability and Disaster Recovery
- Community
  - 20 years Microsoft MVP SQL Server (from 1998)
  - Founder and President UGISS
    - User Group Italiano SQL Server (PASS Chapter)

Security Layering



Data Encryption

- **Transport Layer Security (in transit)**
- **Transparent Data Encryption (at rest)**
- **Cell-Level Encryption (at rest)**
- **Always Encrypted (at rest and in transit)**

Data Access

- **Dynamic Data Masking**
- **Row-Level Security**

Access Control

- **Encrypted Authentication**
- **SQL Firewall***

Proactive monitoring

- **Auditing**
- **Threat Detection***

Scoperta & Controllo accessi

Mettere in sicurezza ambienti SQL Server

Assessment

- Trovare a classificare informazioni in ambito
  - Catalogo metadati (es. sys.columns, moduli SQL)
  - Ricerche Full-Text in campi liberi
- Valutare necessità e proporzionalità protezioni
  - nome, e-mail, carta di credito, malattie, affiliazione politica ecc.
- Mappare flussi da/verso esterno
- Stato dell’arte rispetto a
  - Best Practice
  - Codice condotta/certificazione

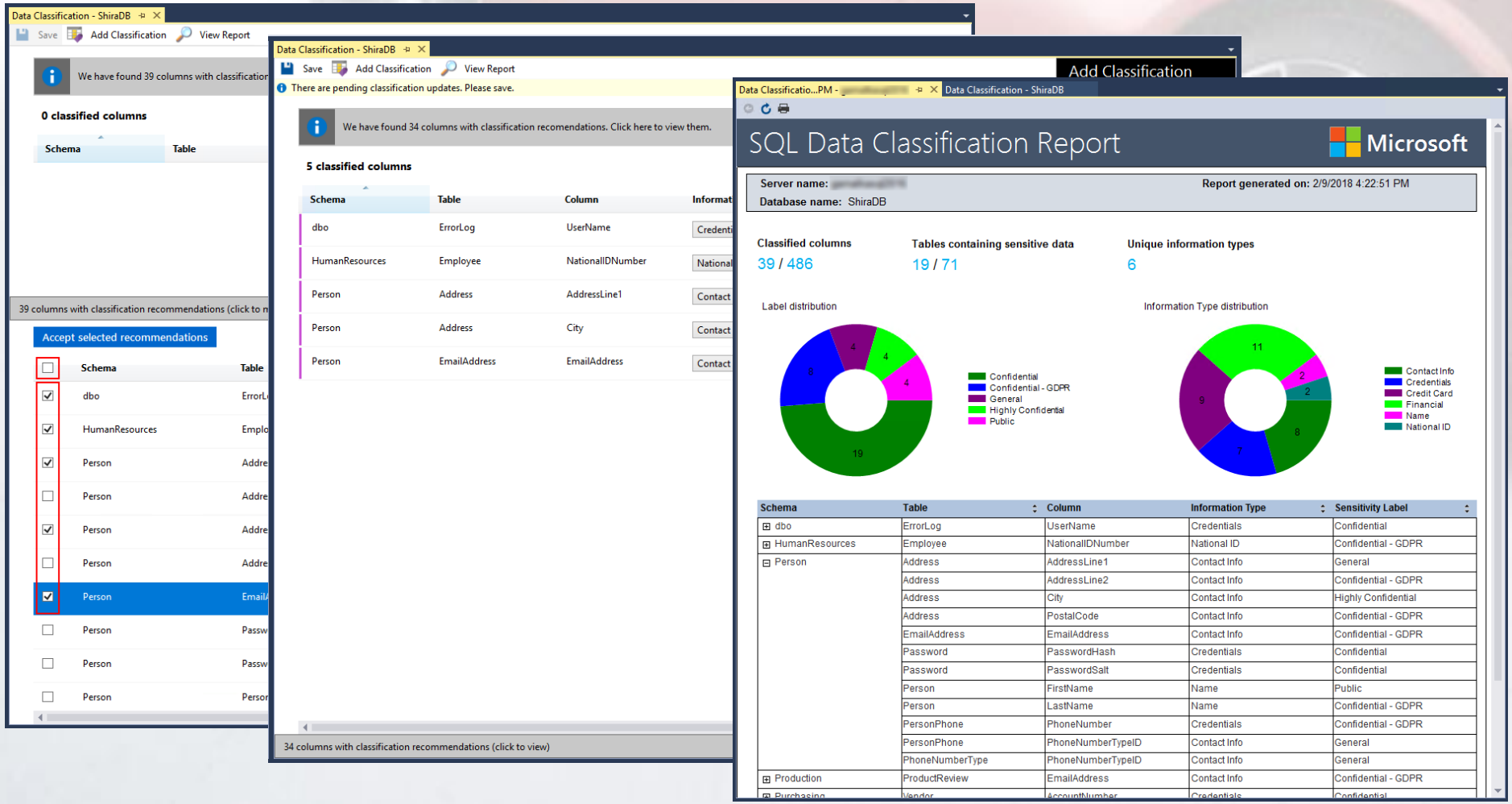
SQL Data Discovery and Classification

- SQL Server management Studio Tool (V17.5)
- Discovery & Recommendations, Labeling, Reporting
- Metadata con be persisted and queried
  - Based on Extended Properties
    - sys_information_type_name, sys_sensitivity_label_name
- Support for SQL Server 2008+ and Azure SQL Database

SQL Server Sensitivity Classification

- SQL Server 2019+
  - (already available in Azure SQL Database)
- T-SQL command **ADD|DROP SENSITIVITY CLASSIFICATION**
  - applies to tables, columns
  - **LABEL**, **LAtBEL_ID**, **INFORMATION_TYPE**, **INFORMATION_TYPE_ID**
- Metadata stored in **sys.sensitivity_classifications**
- SQL Server Audit add column **data_sensitivity_information**

Data Discovery and Classification Demo



DEMO

Classificazione e Data Discovery con SSMS

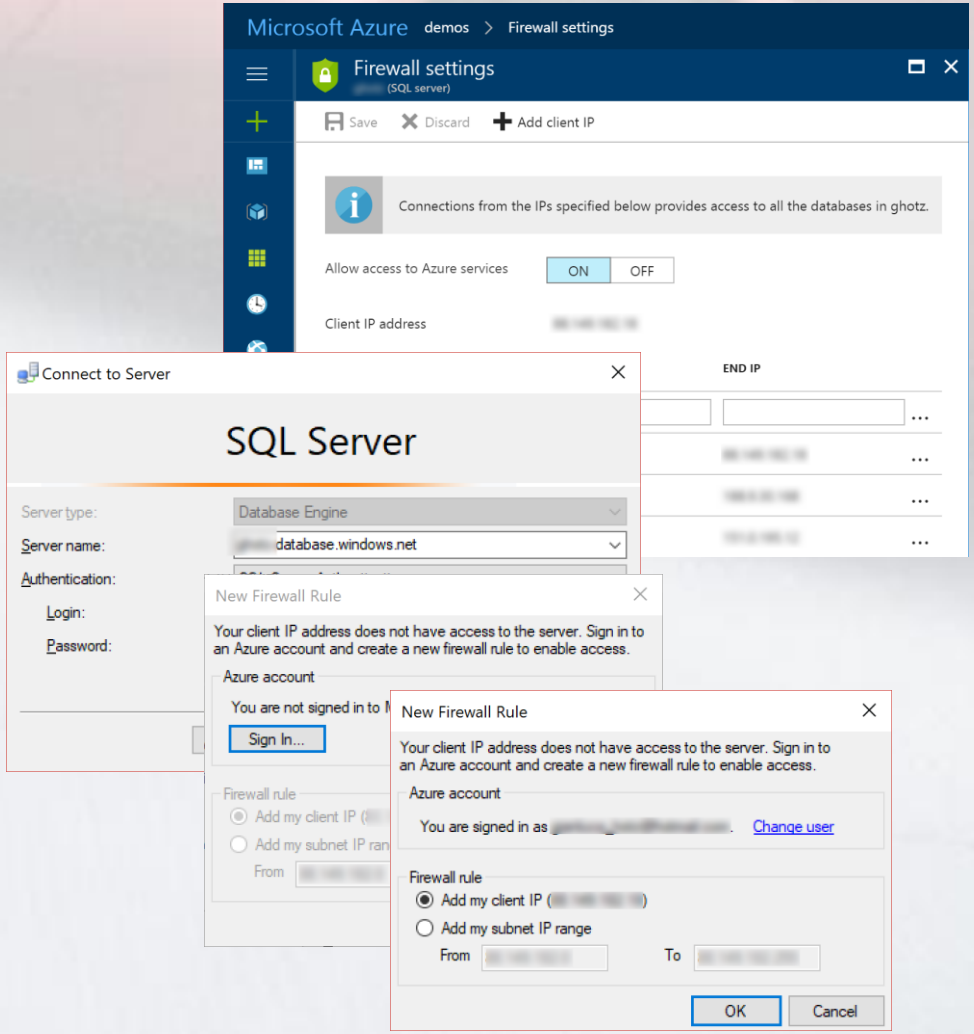
Controllo degli accessi

- Azure Database Firewall (che device)
- Autenticazione (chi sono)
- Autorizzazioni (cosa posso fare)

- Principio guida: minor privilegio!

Azure Database Firewall

- Accesso per servizi Azure
  - Indirizzi IP Specifici
  - Range di indirizzi IP
    - No 0.0.0.0-255.255.255.255 ☺
- Interfaccia SSMS
- Comandi T-SQL
- PowerShell, REST API

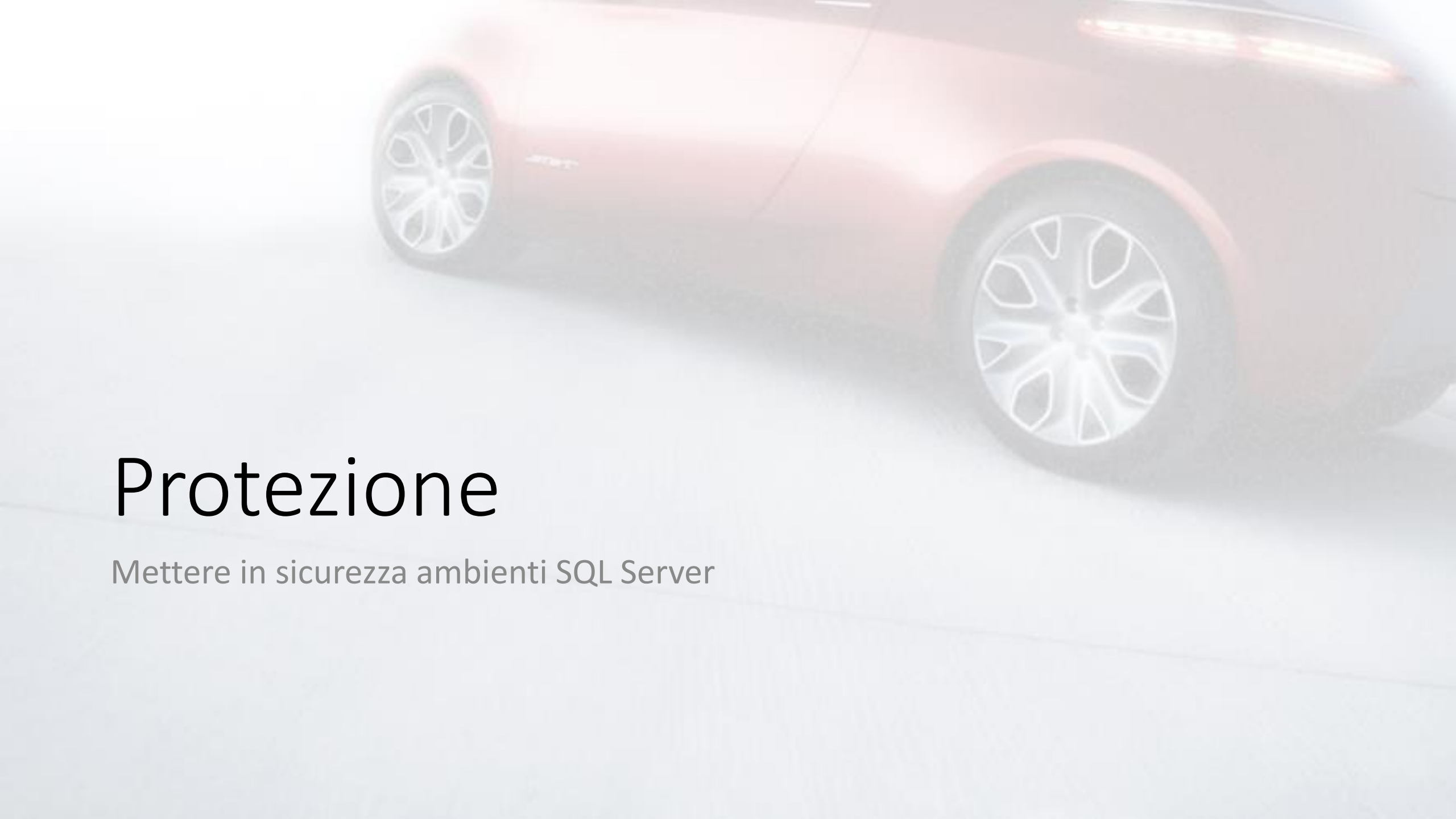


Autenticazione

- Due livelli: Server login e Database User
- Nativa SQL Server
- Integrata con Active Directory
  - Utilizza protocollo Kerberos
  - Supporto Azure Active Directory
  - Supporto Active Directory Universal Authentication
    - Multi-factor Authentication (es. via telefono)
    - Supportata solo con SSMS a partire dalla versione 17
- Best Practice
  - Autenticazione integrata
  - Database Containment (autenticazione a livello database)

Autorizzazioni

- Permessi granulari
  - GRANT cosa può fare ON su che oggetto TO chi
  - Ereditarietà gerarchia di oggetti
  - Assegnazione (GRANT), negazione (DENY), revocare (REVOKE)
  - Row Level Security
- Ruoli a livello di server e database
  - Es. sysadmin, dbcreator, db_datareader, db_datawriter
  - Specifici per alcune funzionalità (database msdb)
- Principio guida: minor privilegio!
  - Possibile elevare temporaneamente
    - Impersonation
    - Stored Procedure (in generale moduli T-SQL firmati)



Protezione

Mettere in sicurezza ambienti SQL Server

Attore principale: crittografia, ma dove?

- Dati in transito
  - Autenticazione (sempre crittografata)
  - Spostamento dati
    - invio richieste (parametri)
    - caricamento in memoria
    - invio risposte (record set)
- Dati a riposo
  - File database (dati e log transazioni)
  - File di trace/audit

Crittografia comunicazioni

- On-premise
  - Installazione Certificato (server e client)
  - Possibile forzare utilizzo (server e client)
  - Autenticazione sempre crittografata (nel caso «self-signed»)
- Azure SQL Database (e SQL Data Warehouse)
  - Connessione crittografata sempre necessaria!
  - Es. connessione ADO.NET Encrypt=True;TrustServerCertificate=False
- Transport Layer Security (TLS) 1.2
  - Windows Server 2008 R2
  - SQL Server 2008 SP4 (hotfix)

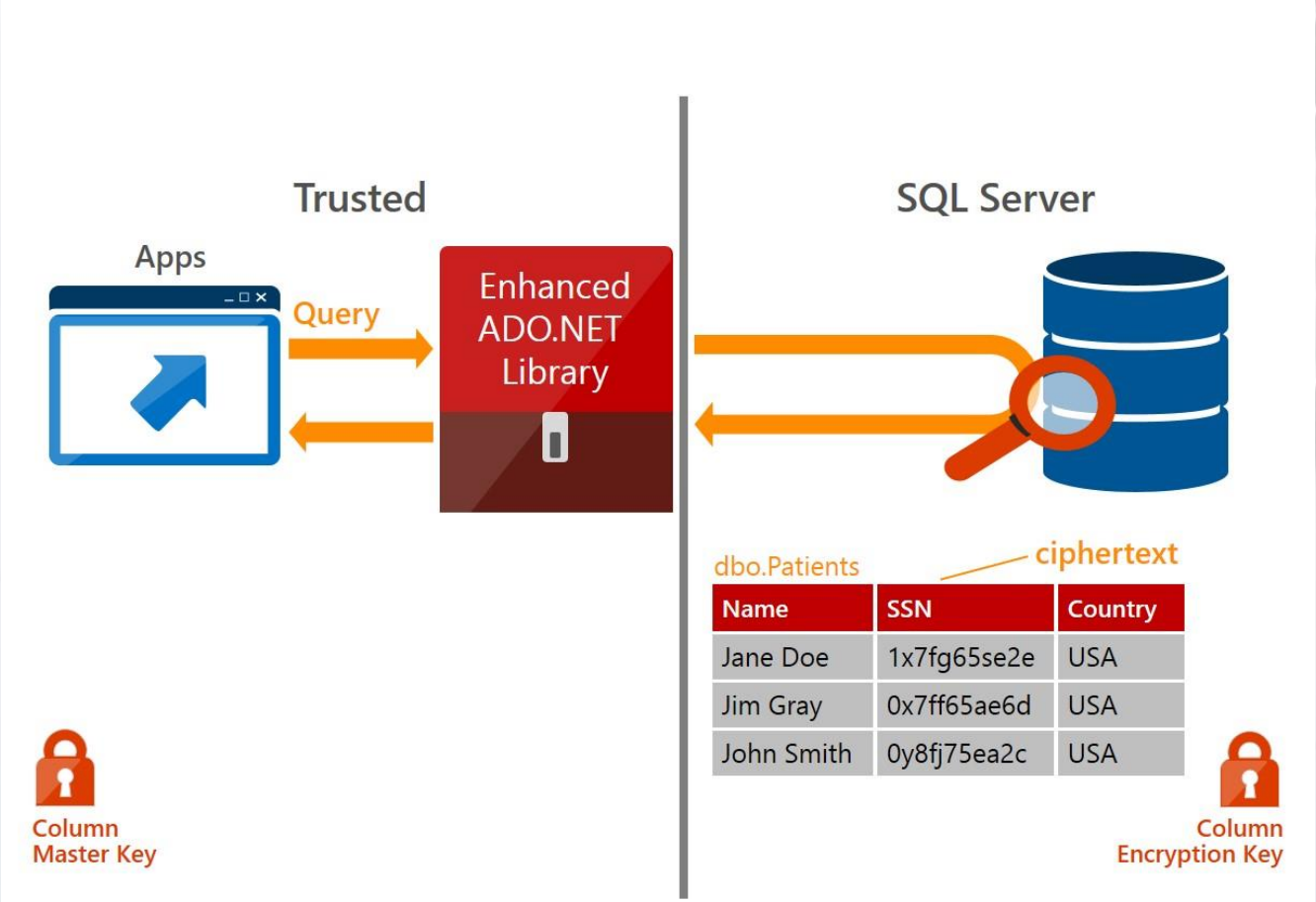
Crittografia dati prima di SQL Server 2016

- Transparent Data Encryption (TDE)
  - File dati, log e backup
  - Dati decifrati quando caricati in memoria*
  - Completamente trasparente per le applicazioni
- Cell-Level Encryption (CLE)
  - Granularità a livello di Colonna
  - Protezione parziale in memoria
  - Non trasparente per le applicazioni
- Entrambi meccanismi crittografici Server-Side
  - Protezione dati a riposo (es. furto dischi o backup)
  - Utenti con privilegi elevati possono ottenere accesso ai dati

Always Encrypted

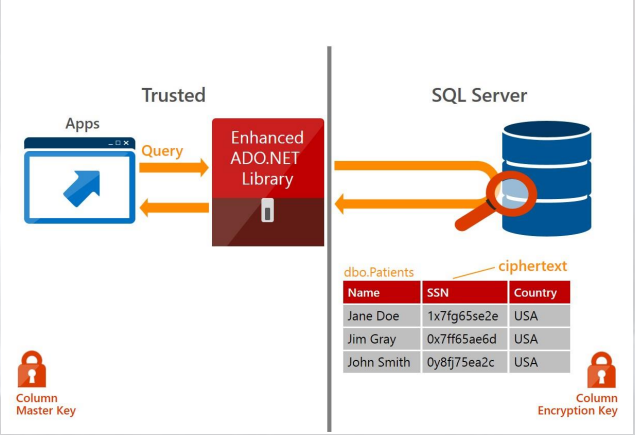
Mettere in sicurezza ambienti SQL Server

Panoramica Always Encrypted



Always Encrypted Keys

- Column Encryption Key (CEK)
  - Usate per crittografare i dati
  - Conservate solo in forma crittografata sul server
  - Legate a specifiche colonne
- Column Master Key (CMK)
  - Usate per crittografare le CEK
  - Conservate in un «key store» esterno
    - Windows Certificate Store, Azure Key Vault, HSM, Custom
  - Deve essere disponibile alle applicazioni



Crittografia dei dati

- Deterministica
  - Permette operazioni di uguaglianza/raggruppamento/join
  - Permette indicizzazione
  - Più debole es. domini con pochi valori come sesso o «flag»
  - Richiede collation _BIN2
- Casuale
  - Nessuna operazione permessa
  - Indicizzazione non permessa
  - Più robusta

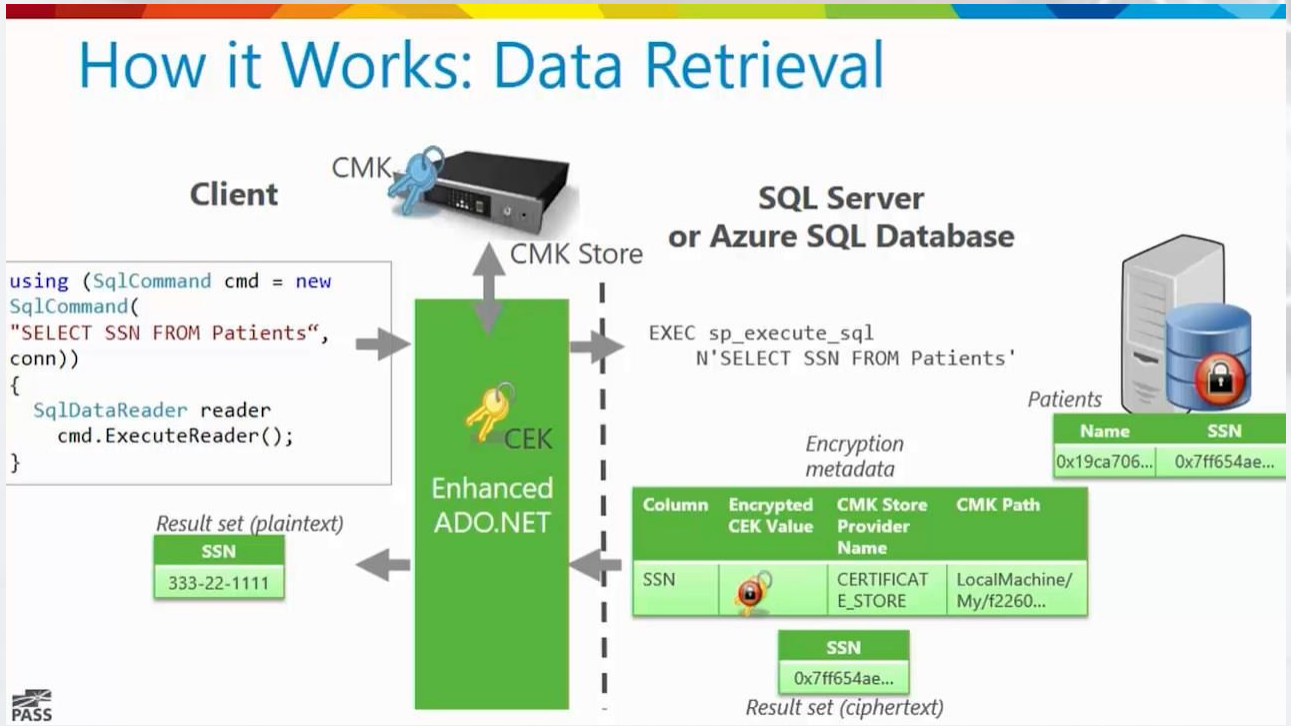
Configurazione Always Encrypted

- SQL Server Management Studio
  - Wizard end-to-end
  - Interfacce specifiche
  - Scenario rotazione chiavi supportato
- Solo parte della configurazione disponibile in T-SQL
  - CMK de crittografata disponibile solo esternamente!
- PowerShell

Configurazione Client Always Encrypted

- Stringa di connessione
  - Column Encryption Setting=Enabled
- Esecuzione di comandi
  - SqlCommand.ColumnEncryptionSetting*
    - Disabled, Enabled, ResultSetOnly, UseConnectionSetting

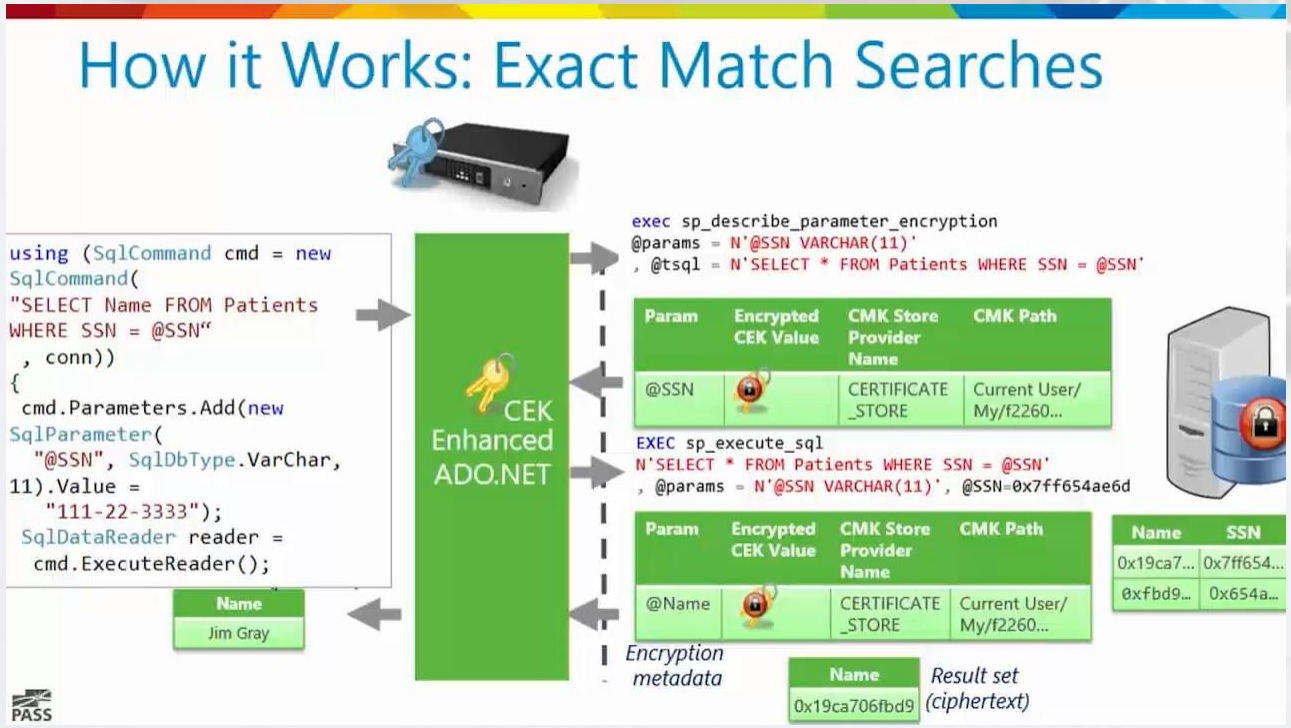
Recupero dati con Always Encrypted



Always Encrypted e parametri

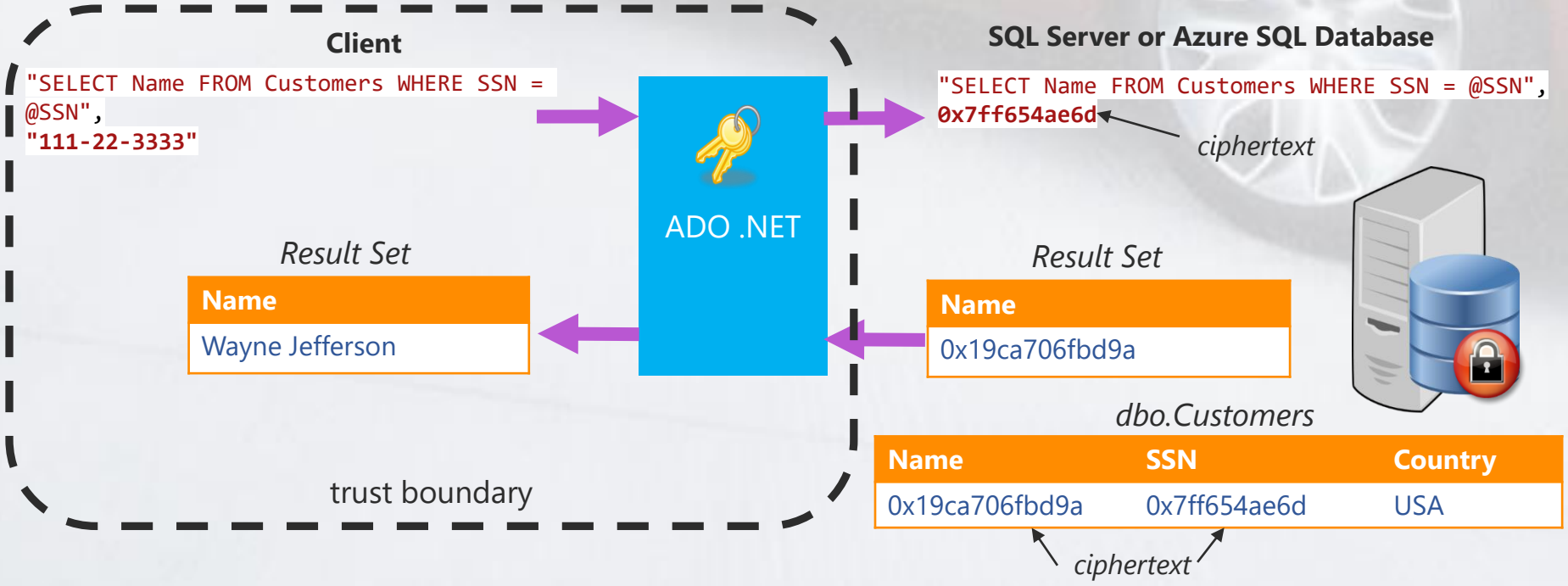
- Comandi parametrizzati necessitano «round-trip»
  - Chiamata a sys.sp_describe_parameter_encryption
  - Ritorna metadati chiavi e chiavi crittografate
  - .NET Framework 4.6.2 mitiga «round-tripping» implementando cache a livello di applicazione
- In generale
  - No query «ad-hoc» con predicati «letterali» (valori costanti)
  - No operazioni tra dati crittografati e dati in chiaro («cyphertexts» e «plaintexts»)
  - Nulla che richieda di de-crittografare i dati lato server

Corrispondenze esatte con Always Encrypted



Flusso corrispondenze esatte AE

I dati sensibili crittografati con le relative chiavi crittografiche non sono mai disponibili in chiaro sul server!

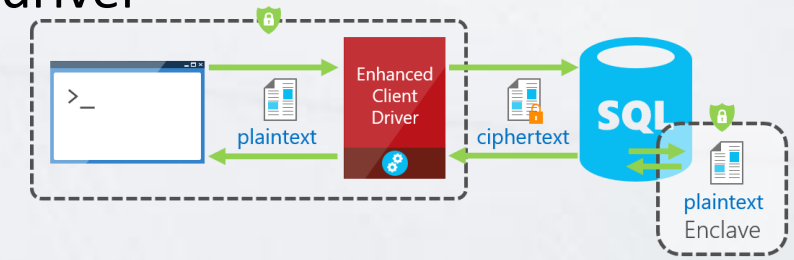


DEMO

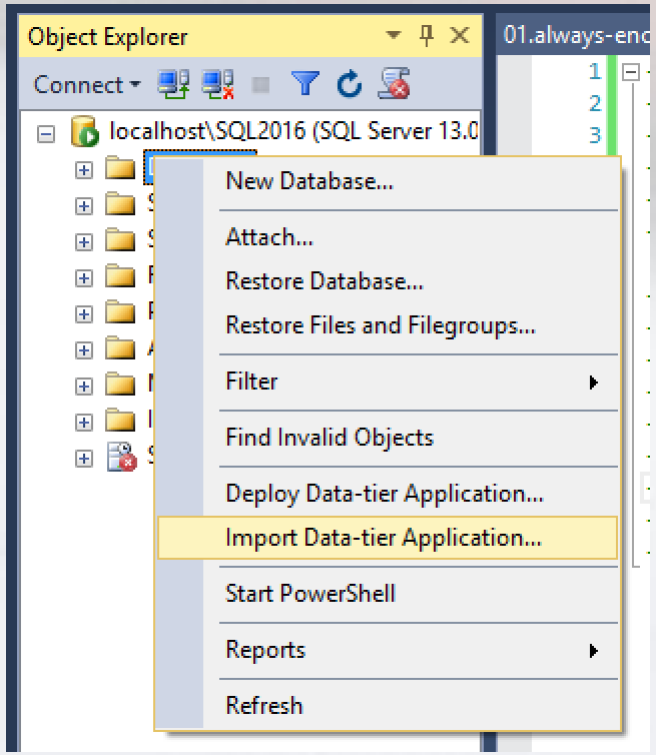
Always Encrypted

Always Encrypted with Secure Enclaves

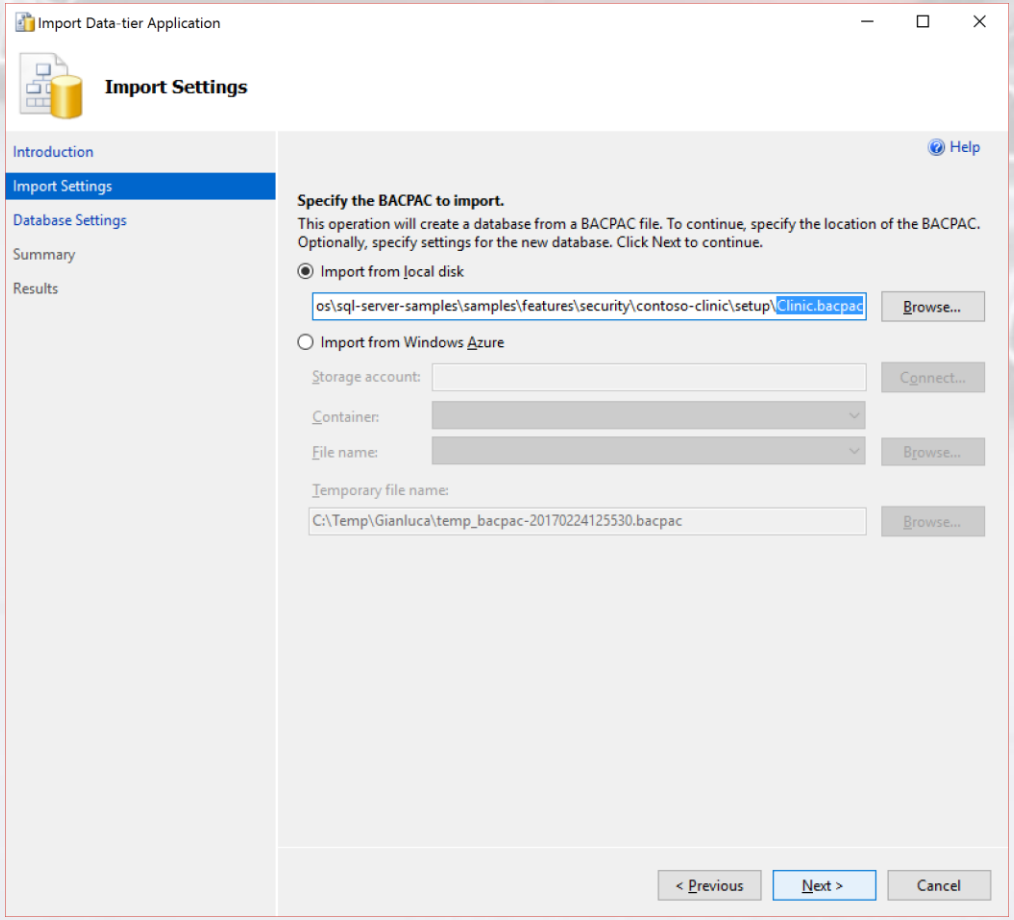
- Basic architecture as SQL Server 2016+ implementation
- Now allows server-side computation on encrypted columns
  - In-Place Encryption (ALTER TABLE for initial encryption)
  - Rich computations (e.g. range comparisons, LIKE predicates, …)
- Inside secure enclaves
  - Virtualization-based Security (VBS) secure memory enclaves
    - also known as Virtual Secure Mode(VSM) enclaves
  - Operation on plaintexts cannot be disclosed outside enclave
  - Column Master Keys sent over secure channel by client driver
- Still some limitations (no indexing)
- Performance optimizations pending…



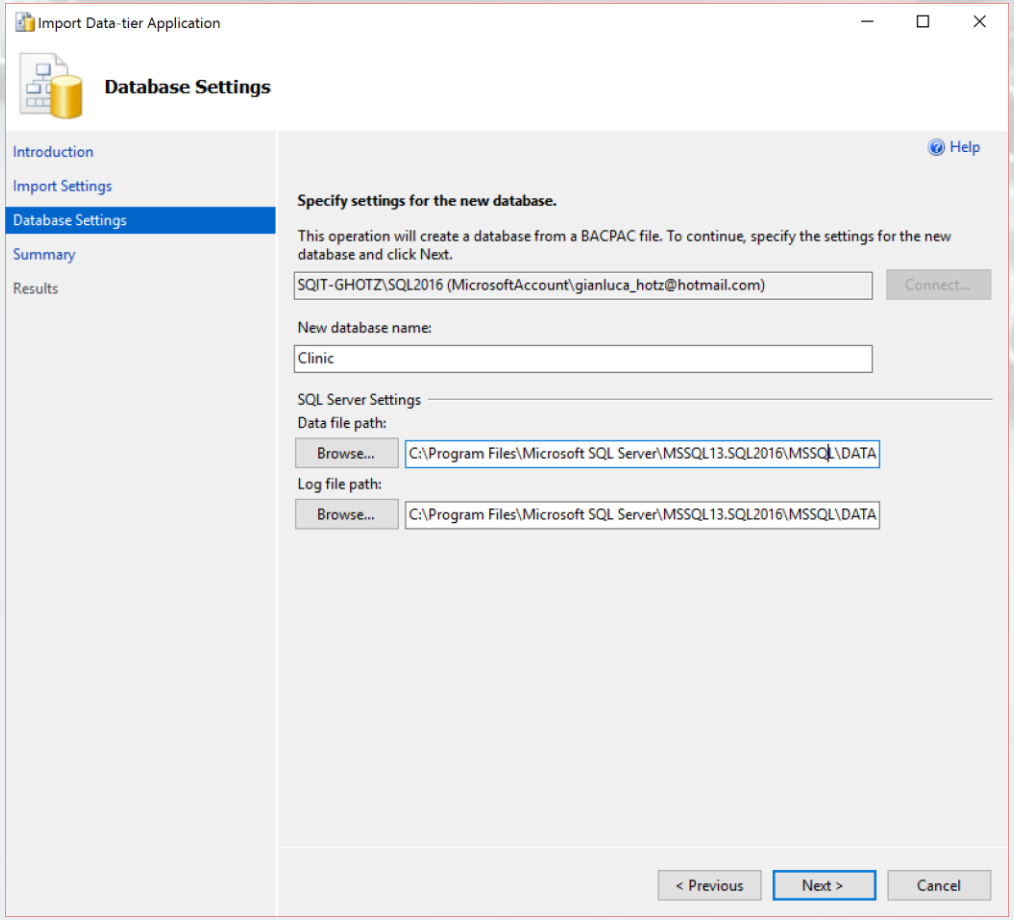
Import: Menu


Object Explorer
Connect
localhost\SQL2016 (SQL Server 13.0
01.always-enc
New Database...
Attach...
Restore Database...
Restore Files and Filegroups...
Filter
Find Invalid Objects
Deploy Data-tier Application...
Import Data-tier Application...
Start PowerShell
Reports
Refresh

Import: Settings



Import: Database Settings



Application (unencrypted data)

Index - Contoso Clinic

localhost:1192/Patients

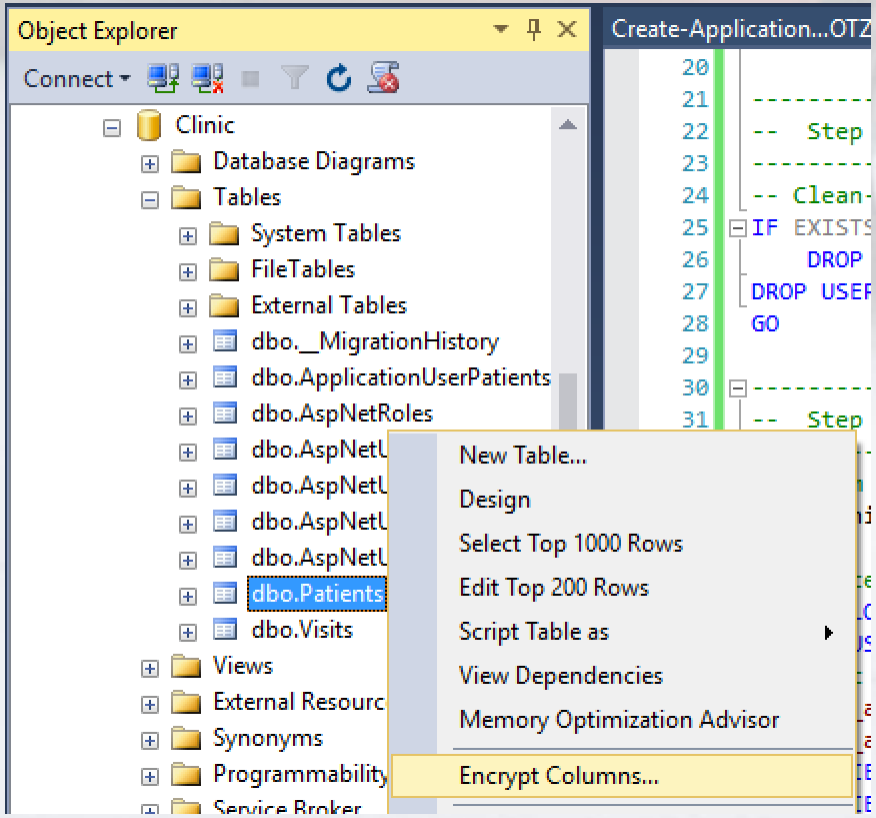
Contoso Clinic | Home | Patients | Visits | About | Contact | Register | Log in

Index

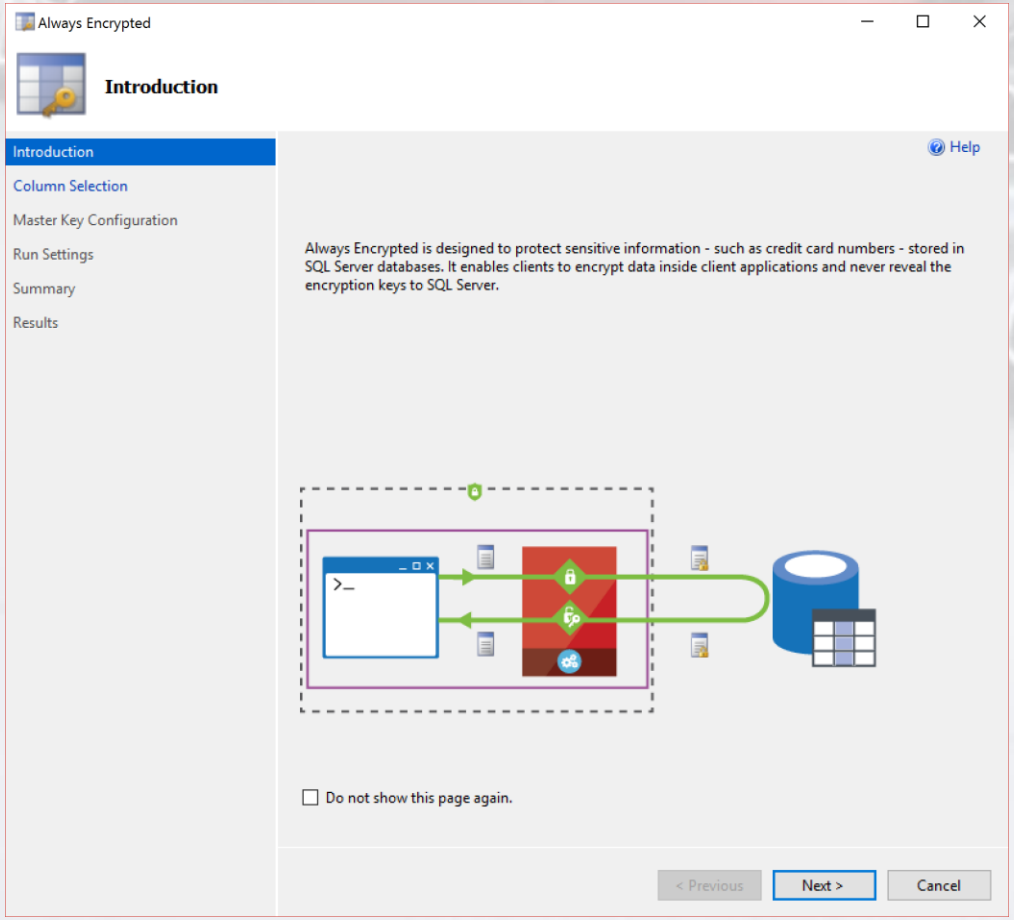
Create New

SSN	FirstName	LastName	MiddleName	StreetAddress	City	ZipCode	State	BirthDate	
795-73-9838	Catherine	Abel	R.	57251 Serene Blvd	Van Nuys	91411	CA	10/09/1996 00:00:00	Edit | Details | Delete
990-00-6818	Kim	Abercrombie		Tanger Factory	Branch	55056	MN	05/06/1967 00:00:00	Edit | Details | Delete
009-37-3952	Frances	Adams	B.	6900 Sisk Road	Modesto	95354	CA	26/12/2005 00:00:00	Edit | Details | Delete
708-44-3627	Jay	Adams		Blue Ridge Mall	Kansas City	64106	MS	28/12/2011 00:00:00	Edit | Details | Delete
447-62-6279	Robert	Ahlering	E.	6500 East Grant Road	Tucson	85701	AZ	01/12/1953 00:00:00	Edit | Details | Delete
872-78-4732	Stanley	Alan	A.	567 Sw Mcloughlin Blvd	Milwaukie	97222	OR	15/09/1967 00:00:00	Edit | Details | Delete
898-79-8701	Paul	Alcorn	L.	White Mountain Mall	Rock Springs	82901	WY	23/03/2010 00:00:00	Edit | Details | Delete
561-88-3757	Mary	Alexander		2345 West Spencer Road	Lynnwood	98036	WA	20/02/1985 00:00:00	Edit | Details | Delete

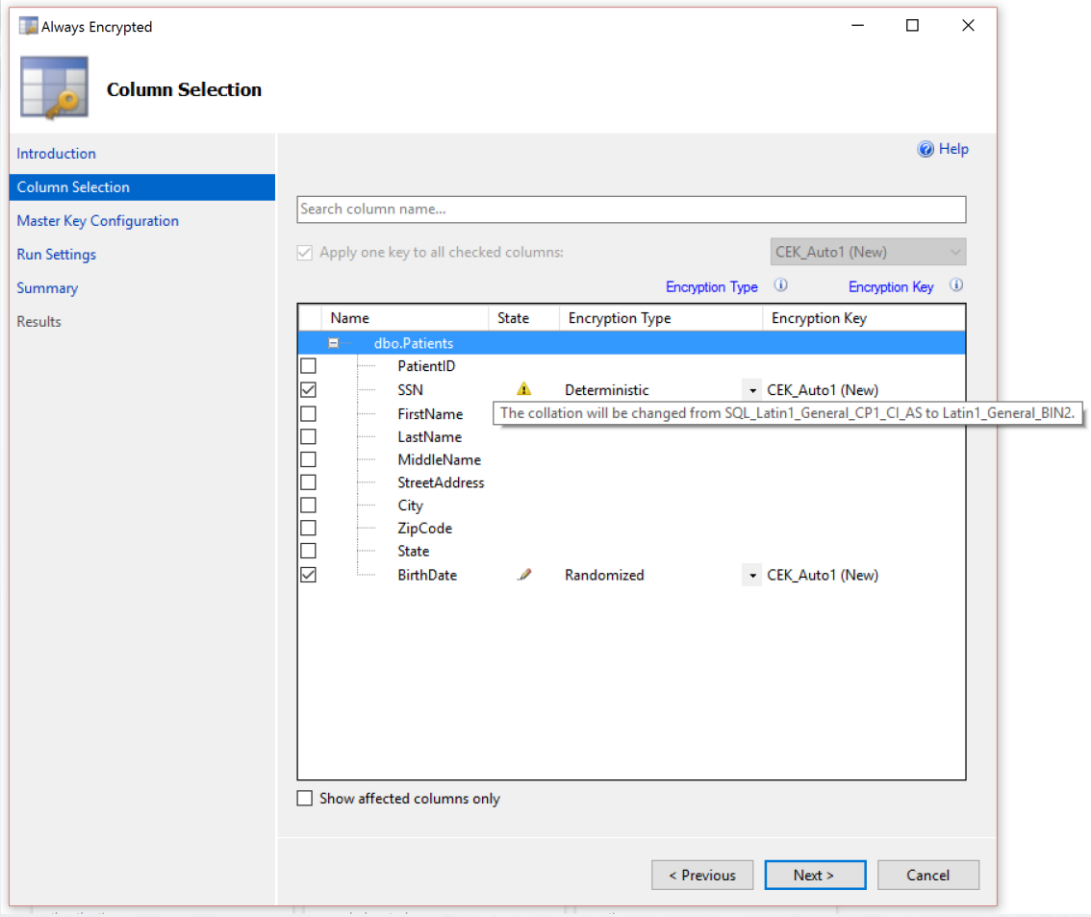
Encrypt columns: menu



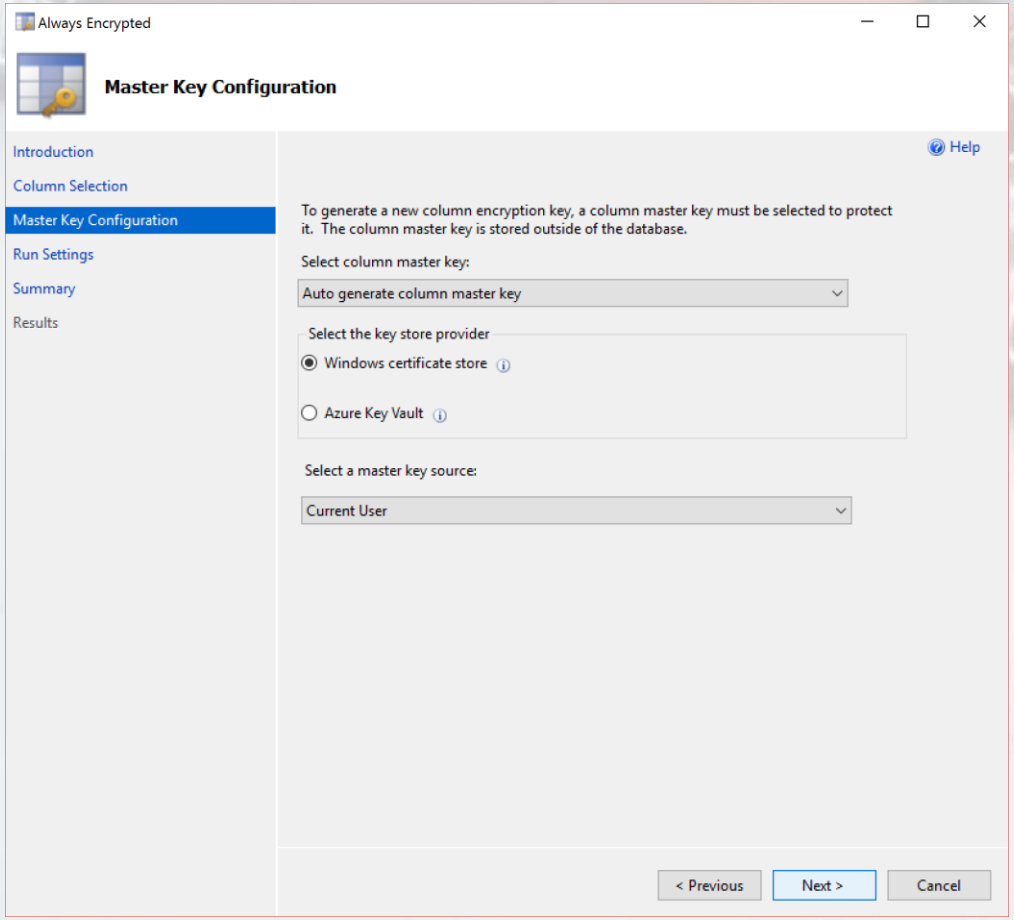
Encrypt columns: introduction



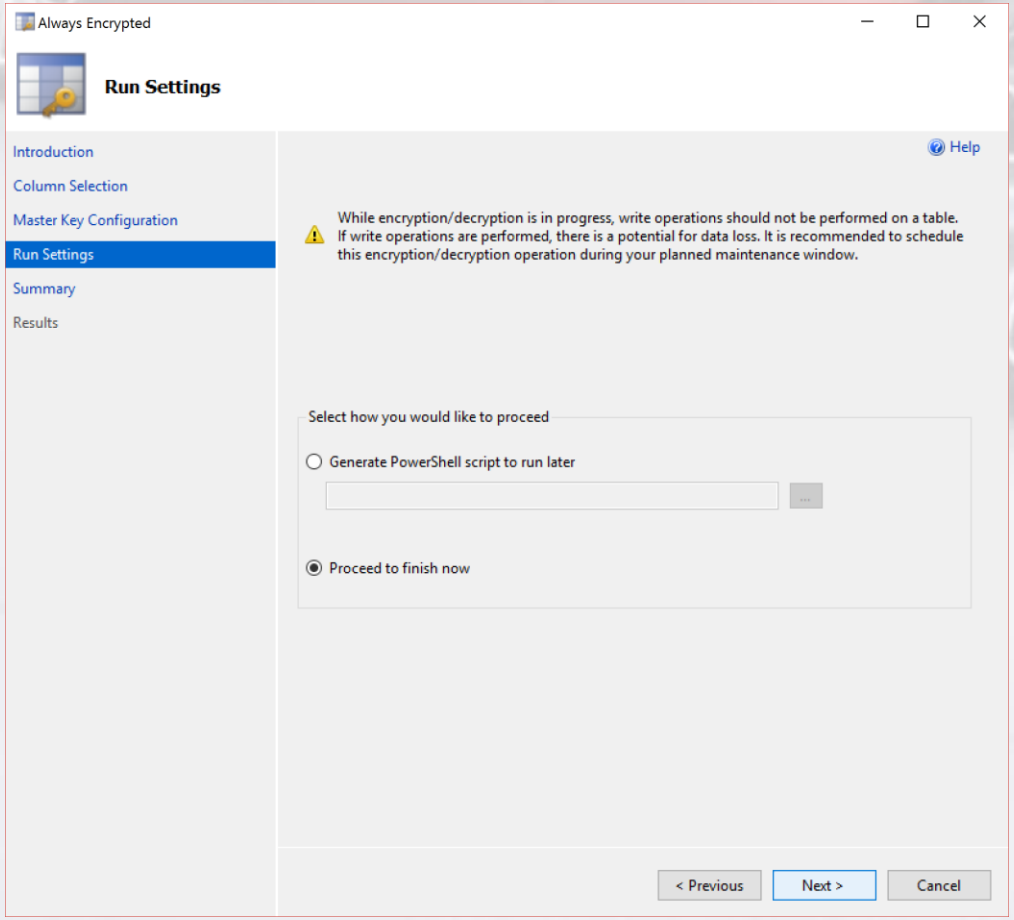
Encrypt columns: column selection



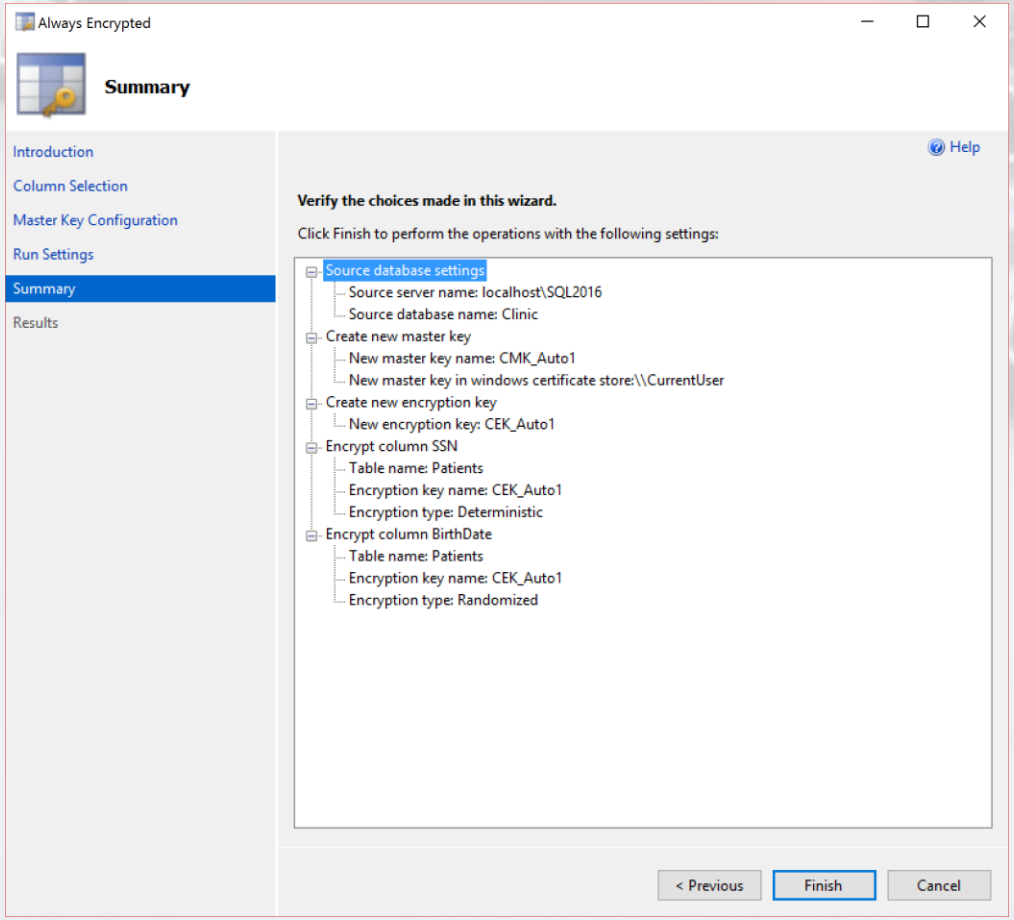
Encrypt columns: Master Key config



Encrypt columns: run settings



Encrypt columns: summary



Encrypted data in SSMS

```sql
-- Show encrypted data in SSMS
SELECT * FROM Clinic.dbo.Patients;
GO
```

100 %

Results | Messages

	PatientID	SSN	FirstName	LastName	MiddleName	StreetAddress	City	ZipCode	State	BirthDate
1	1	0x0160E909C63EE21D58A72E7C893BC9076E682A537A7B18A13...	Catherine	Abel	R.	57251 Serene Blvd	Van Nuys	91411	CA	0x01938ABA0
2	2	0x019B05FAD050081CF81F97368737797689223D712FBFD33194...	Kim	Abercrombie		Tanger Factory	Branch	55056	MN	0x01DD006B
3	3	0x01F72CD519F0C23D40F56531FC7CBFB39704DE7CF90D1C4C...	Frances	Adams	B.	6900 Sisk Road	Modesto	95354	CA	0x015AEB473
4	4	0x01101C4775EA9C55E2D103B96F5007AAE0467ECCE96D9106...	Jay	Adams		Blue Ridge Mall	Kansas City	64106	MS	0x011712067
5	5	0x0106AF0D561164D8BC602E0856CC2188B044A8CE8A30DACC...	Robert	Ahlering	E.	6500 East Grant Road	Tucson	85701	AZ	0x0114250CB
6	6	0x01B62D1FF608141F89715ED3431F17FFF7CBFB07458991BE0...	Stanley	Alan	A.	567 Sw Mcloughlin Blvd	Milwaukie	97222	OR	0x016193A34
7	7	0x01CA5DD0DB7D5CA6B4EFED3CC1262DB445FDC67E5BC151...	Paul	Alcorn	L.	White Mountain Mall	Rock Springs	82901	WY	0x0186E94CB
8	8	0x01F26948283A3E19CAE420084D6840A74DCABA1524842EF75...	Mary	Alexander		2345 West Spencer Road	Lynnwood	98036	WA	0x01DD89EB
9	9	0x01E4B417E79D811DBFC3BAD42D6140F1A3FA08CAA055C9E5...	Michelle	Alexander		22589 West Craig Road	North Las Vegas	89030	NV	0x015046705
10	10	0x017D1429FCFB69803421961ABBC00608A73E0E143D75F5904...	Marvin	Allen	N.	First Colony Mall	Sugar Land	77478	TX	0x01B53CE92
11	11	0x018DB025E136F3338F37202089DD2705757FD3C1FF74ECC4F...	Oscar	Alpuerto	L.	Rocky Mountain Pines Outlet	Loveland	80537	CO	0x018571BFC
12	12	0x01BFB7A4F9D7D41A7CEC55DF4B4DF6C0F68ACB7CE02162B...	Ramona	Antrim	J.	998 Forest Road	Saginaw	48601	MI	0x01C678502

Application: encrypted data type error

The 'SSN' property on 'I

localhost:1192/Patients

Server Error in '/' Application.

The 'SSN' property on 'Patient' could not be set to a 'System.Byte[]' value. You must set this property to a non-null value of type 'System.String'.

Description: An unhandled exception occurred during the execution of the current web request. Please review the stack trace for more information about the error and where it originated in the code.

Exception Details: System.InvalidOperationException: The 'SSN' property on 'Patient' could not be set to a 'System.Byte[]' value. You must set this property to a non-null value of type 'System.String'.

Source Error:

```
Line 18:        public ActionResult Index()
Line 19:        {
Line 20:            return View(db.Patients.ToList());
Line 21:        }
Line 22:
```

Source File: C:\Users\Gianluca\Source\Repos\sql-server-samples\samples\features\security\contoso-clinic\src\ContosoClinic\Controllers\PatientsController.cs **Line:** 20

Stack Trace:

```
[InvalidOperationException: The 'SSN' property on 'Patient' could not be set to a 'System.Byte[]' value. You must set this property to a non-null
   System.Data.Entity.Core.Common.Internal.Materialization.ErrorHandlingValueReader`1.GetValue(DbDataReader reader, Int32 ordinal) +235
   lambda_method(Closure , Shaper ) +442
   System.Data.Entity.Core.Common.Internal.Materialization.Shaper.HandleEntityAppendOnly(Func`2 constructEntityDelegate, EntityKey entityKey, Enti
   lambda_method(Closure , Shaper ) +317
   System.Data.Entity.Core.Common.Internal.Materialization.Coordinator`1.ReadNextElement(Shaper shaper) +181
   System.Data.Entity.Core.Common.Internal.Materialization.SimpleEnumerator.MoveNext() +76
   System.Data.Entity.Internal.LazyEnumerator`1.MoveNext() +112
   System.Collections.Generic.List`1..ctor(IEnumerable`1 collection) +275
```

Encrypted data ad-hoc/params queries

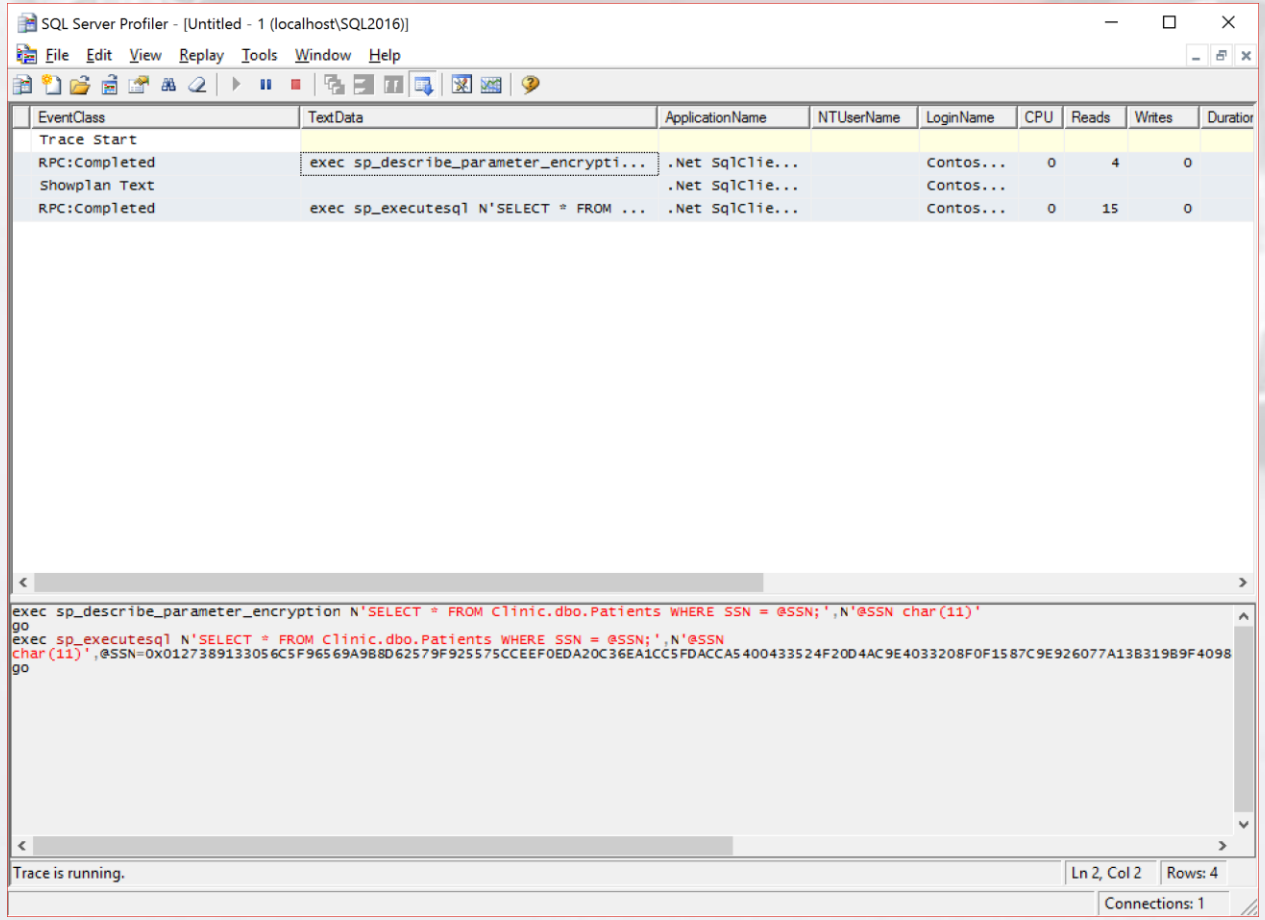
```
88  --
89  -- Ad-hoc queries on regular columns continue to work
90  SELECT * FROM Clinic.dbo.Patients WHERE FirstName = 'Catherine';
91  GO
92
93  -- But not on encrypted columns
94  SELECT * FROM Clinic.dbo.Patients WHERE SSN = '795-73-9838';
95  GO
96  DECLARE @SSN char(11) = '795-73-9838';
97  SELECT * FROM Clinic.dbo.Patients WHERE SSN = @SSN
```

100 %

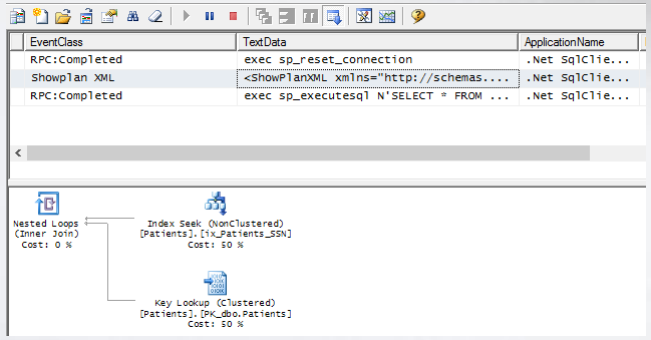
Messages

```
Msg 206, Level 16, State 2, Line 94
Operand type clash: varchar is incompatible with varchar(8000) encrypted with (e
Msg 33299, Level 16, State 6, Line 97
Encryption scheme mismatch for columns/variables '@SSN'. The encryption scheme f
```

Parametrized Commands Round-trip



Parametrized Commands Round-trip



Benefici Always Encrypted

- Protegge in caso di violazione dei dati
  - Database Engine ma ricordatevi…
  - … del «middle-tier»!
- Permette distribuzione/gestione
  - attraverso confini geo-politici
- GDPR
  - Art. 9 «Processing of special categories of personal data»
  - Art. 32 «Security of processing»

Row Level Security

Mettere in sicurezza ambienti SQL Server

Panoramica Row Level Security

- Restringe l’accesso a un sottoinsieme di righe
- Basata su predicati di sicurezza
  - Definiti come «inline Table-Valued Functions»
  - «Filter predicate» limita righe a operazioni in lettura
    - SELECT, UPDATE e DELETE
  - «Block predicate» bloccano operazioni di scrittura
    - AFTER INSERT, AFTER/BEFORE UPDATE, BEFORE DELETE
- «Security Policy»
  - Applica i predicati di sicurezza alle tabelle

«Row-Level Security»

Due
Il security policy (che contiene il predicato) viene associato alla tabella dei pazienti. Il predicato è una funzione T-SQL, vincolando il predicato alla tabelle dei pazienti.

Application

```
SELECT * FROM Patients
```

Database

Security Policy

Filter Predicate: INNER JOIN…

Patients

```
CREATE FUNCTION dbo.fn_securitypredicate(@wing int)
    RETURNS TABLE WITH SCHEMABINDING AS
    return SELECT 1 as [fn_securitypredicate_result] FROM
SELECT * FROM Patients
   SEMIJOIN APPLY dbo.fn_securitypredicate(patients.Wing);
        WHERE e.UserSID = SUSER_SID() AND @wing = d.Wing;
SELECT Patients.* FROM Patients,
   StaffDuties d INNER JOIN Employees e ON (d.EmpId = e.EmpId)
   WHERE e.UserSID = SUSER_SID() AND Patients.wing = d.Wing;
```

Row-Level Security & Multi Tenancy

- Vincola accesso ai «tenant» quando «shard» condividono le stesse tabelle
- Assumendo esistenza colonna che identifica il «tenant»

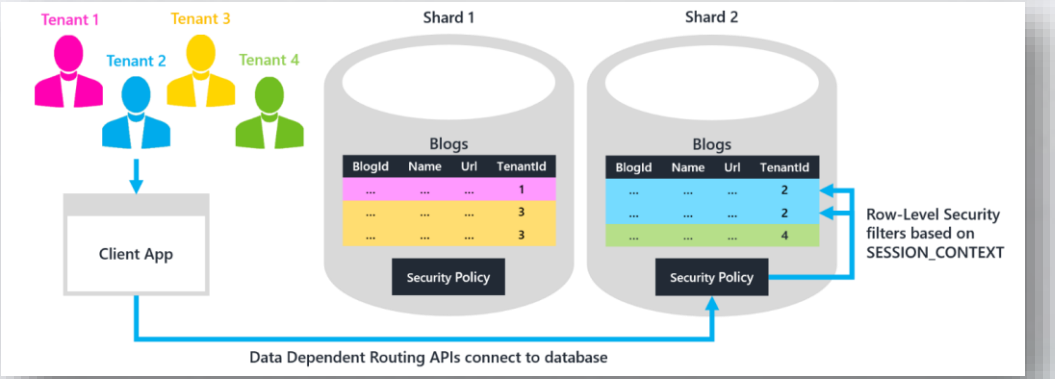
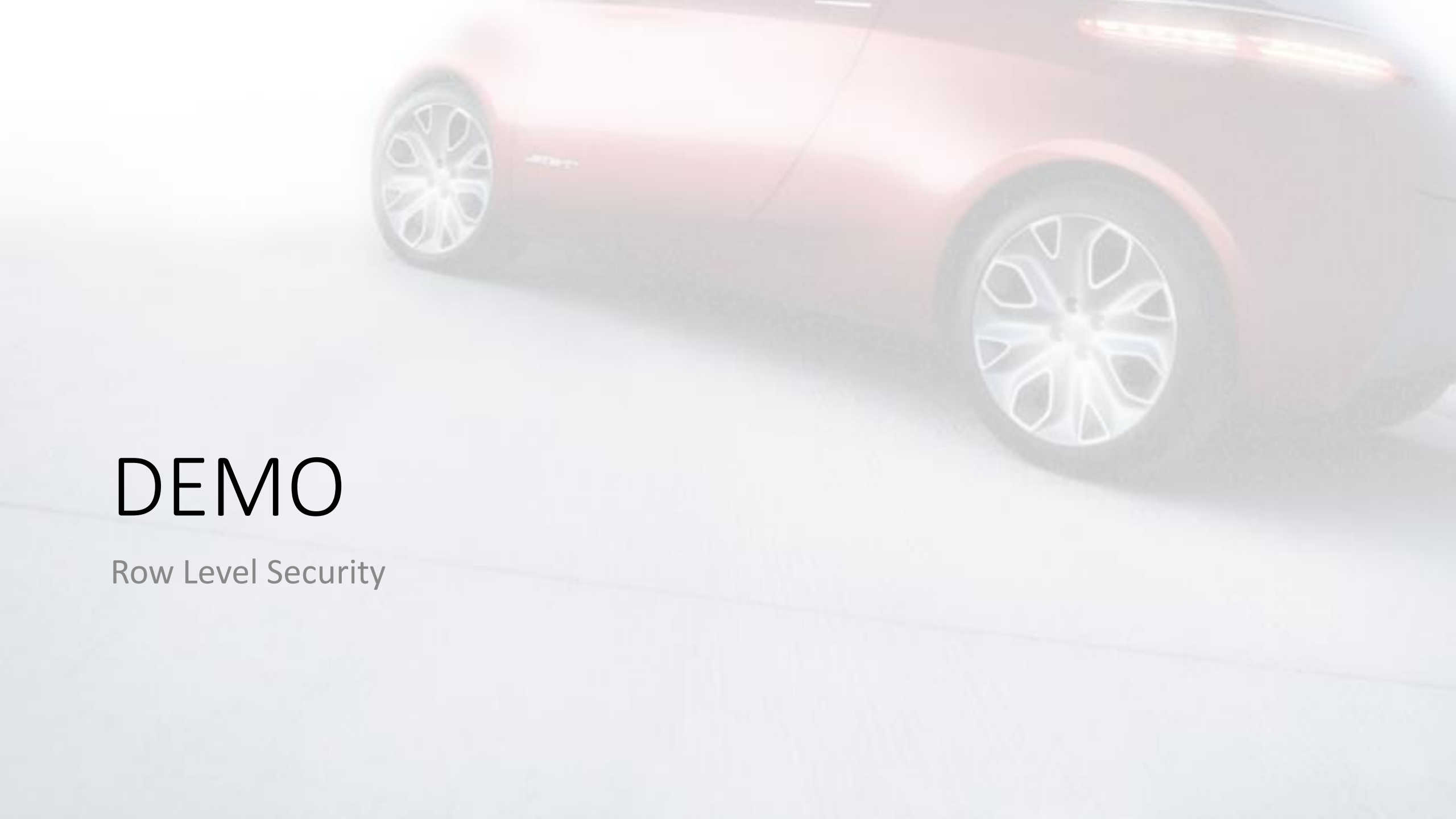


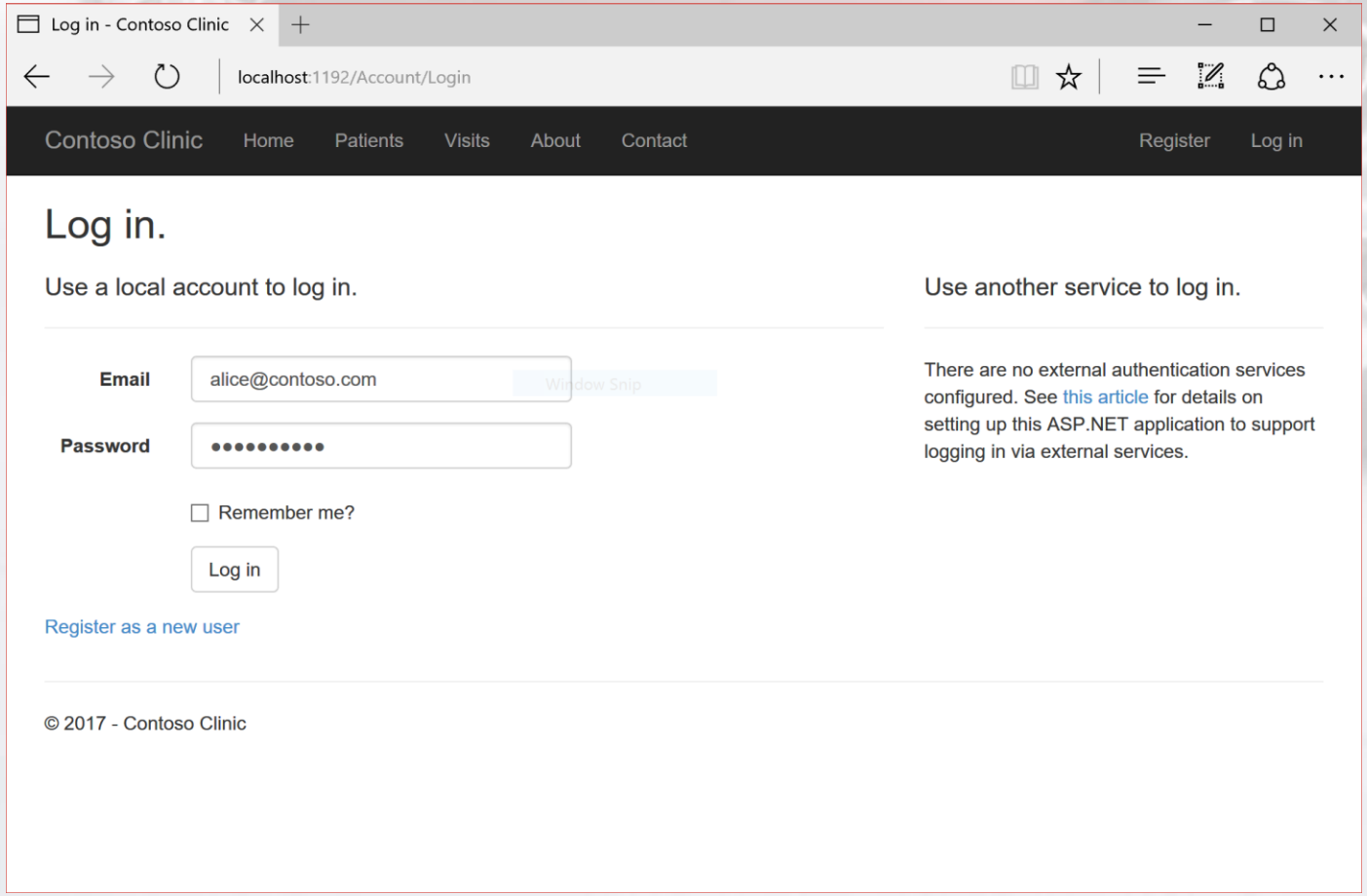
Image source: https://docs.microsoft.com/en-us/azure/sql-database/sql-database-elastic-tools-multi-tenant-row-level-security



DEMO

Row Level Security

RLS: Alice login



RLS: Alice sees her patients

Index - Contoso Clinic

localhost:1192/Patients

Contoso Clinic | Home | Patients | Visits | About | Contact | Hello alice@contoso.com! | Log off

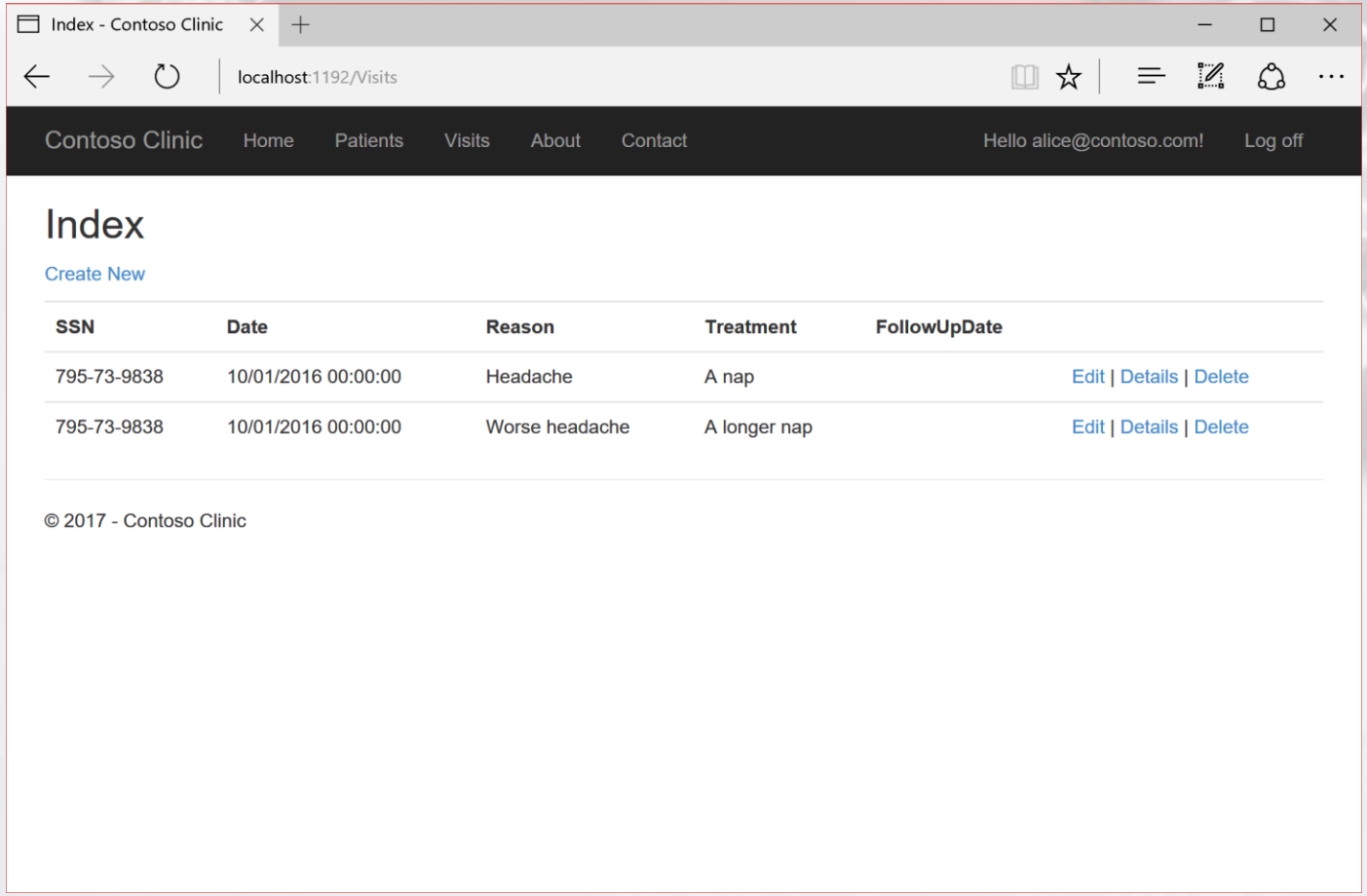
Index

Create New

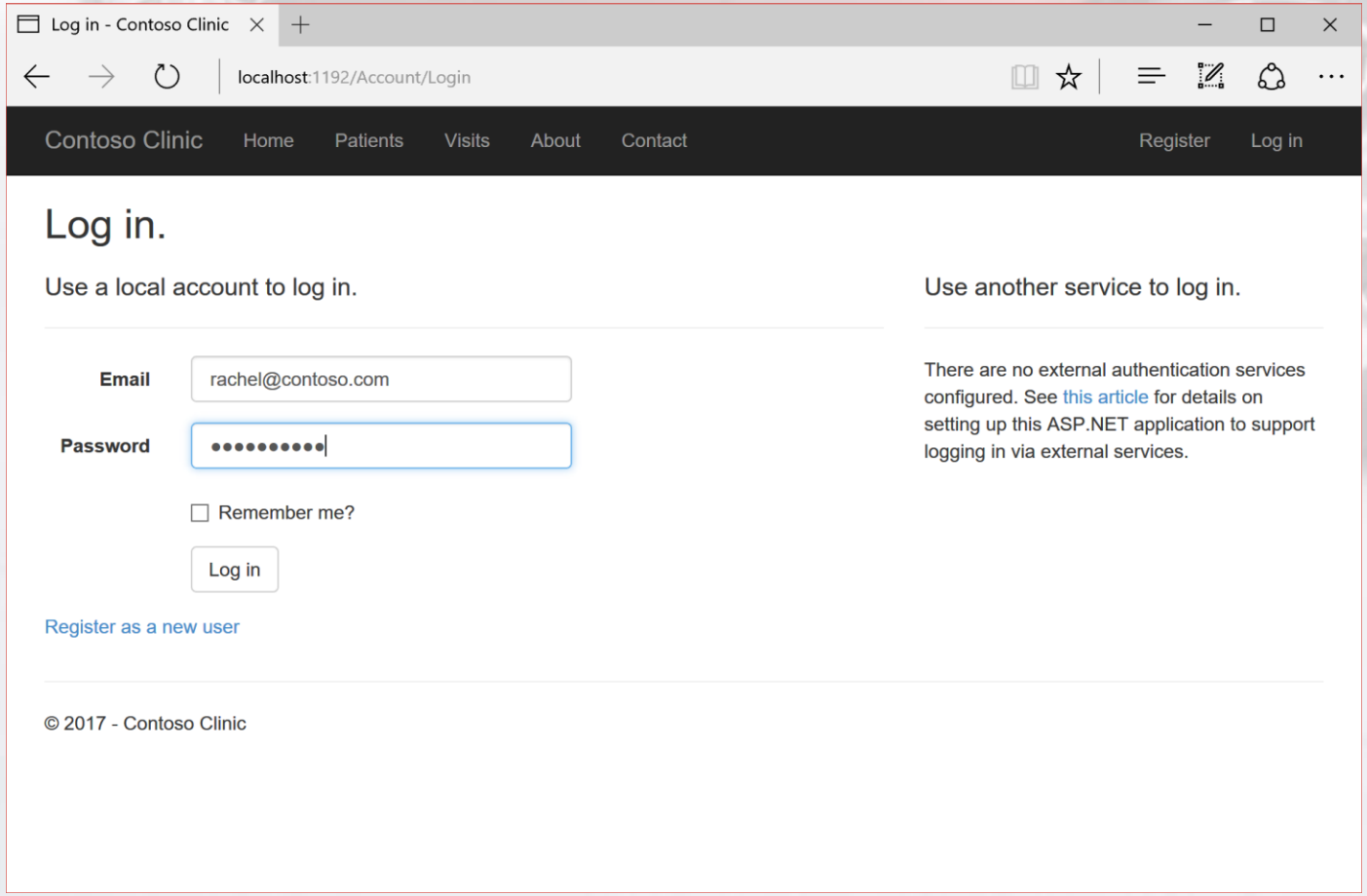
SSN	FirstName	LastName	MiddleName	StreetAddress	City	ZipCode	State	BirthDate	
795-73-9838	Catherine	Abel	R.	57251 Serene Blvd	Van Nuys	91411	CA	10/09/1996 00:00:00	Edit | Details | Delete
990-00-6818	Kim	Abercrombie		Tanger Factory	Branch	55056	MN	05/06/1967 00:00:00	Edit | Details | Delete
009-37-3952	Frances	Adams	B.	6900 Sisk Road	Modesto	95354	CA	26/12/2005 00:00:00	Edit | Details | Delete
708-44-3627	Jay	Adams		Blue Ridge Mall	Kansas City	64106	MS	28/12/2011 00:00:00	Edit | Details | Delete
447-62-6279	Robert	Ahlering	E.	6500 East Grant Road	Tucson	85701	AZ	01/12/1953 00:00:00	Edit | Details | Delete

© 2017 - Contoso Clinic

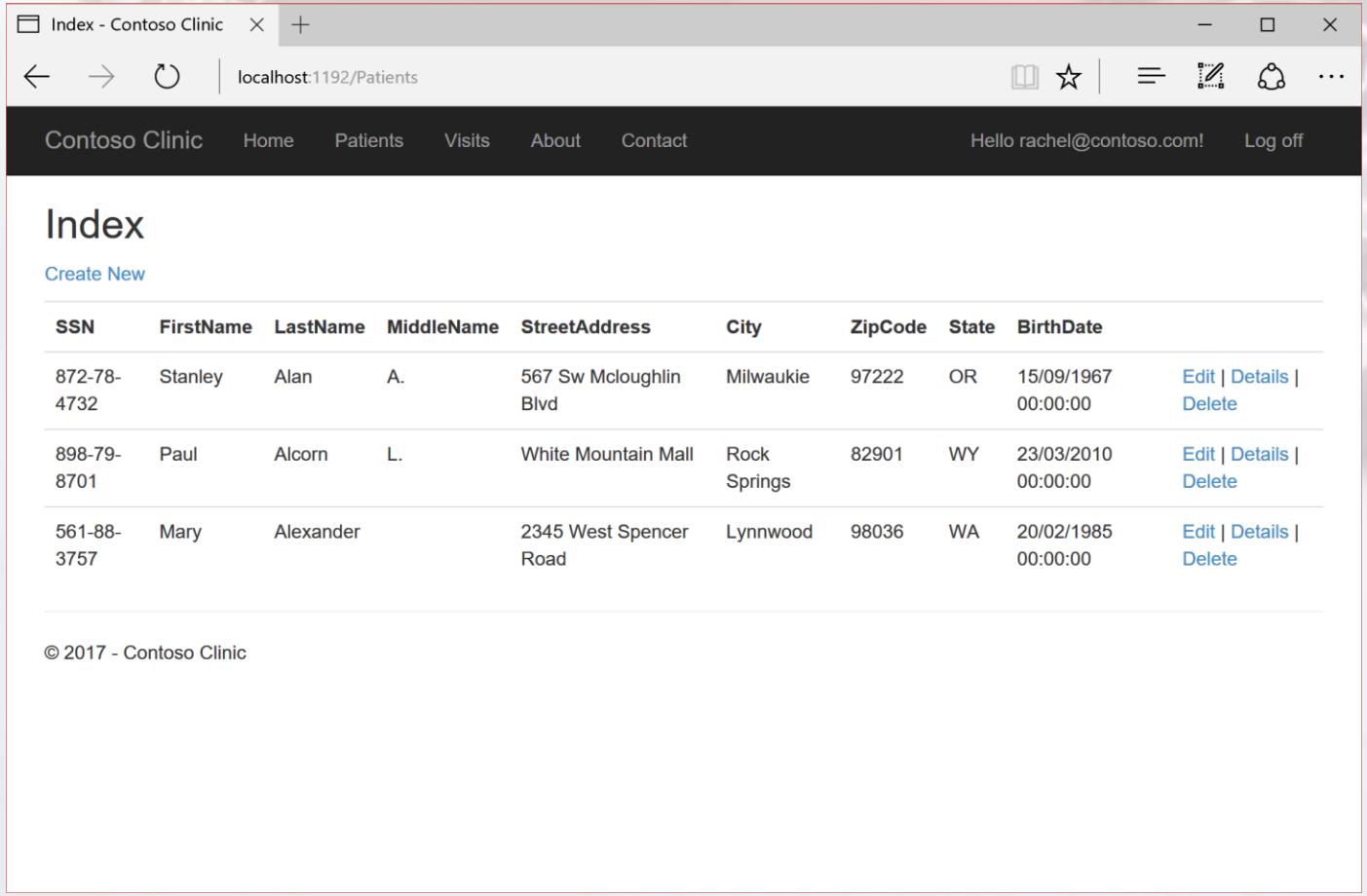
RLS: Alice sees her patients' visits



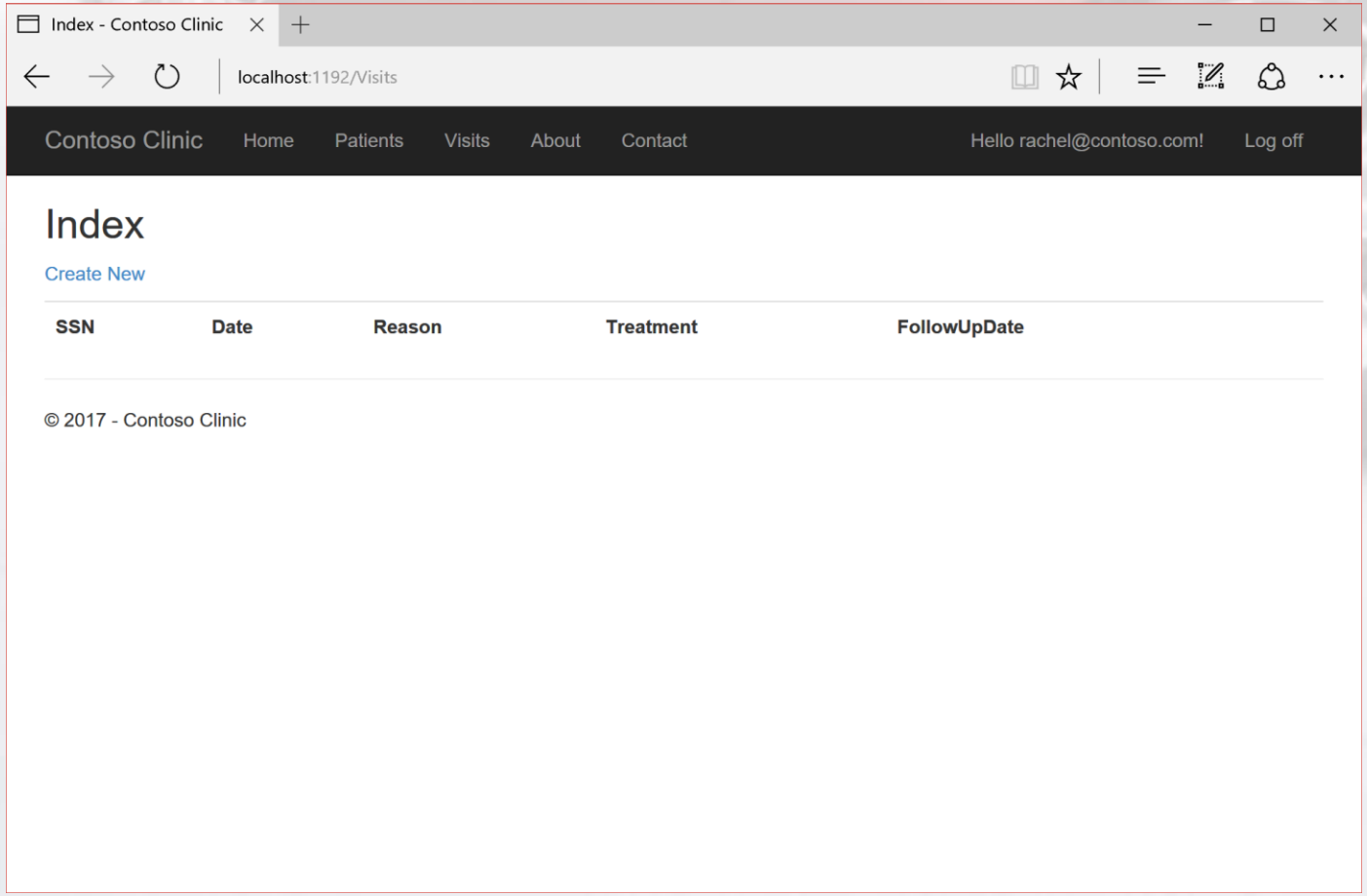
RLS: Rachel login



RLS: Rachel sees her patients



RLS: Rachel patients have no visits yet

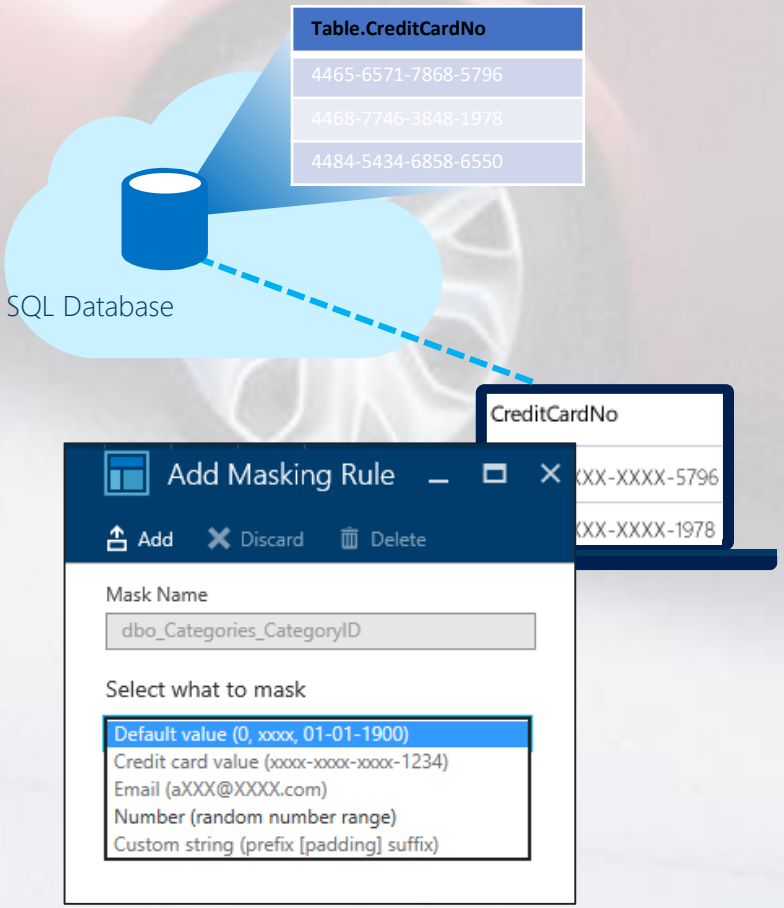


Dynamic Data Masking

Mettere in sicurezza ambienti SQL Server

Dynamic Data Masking

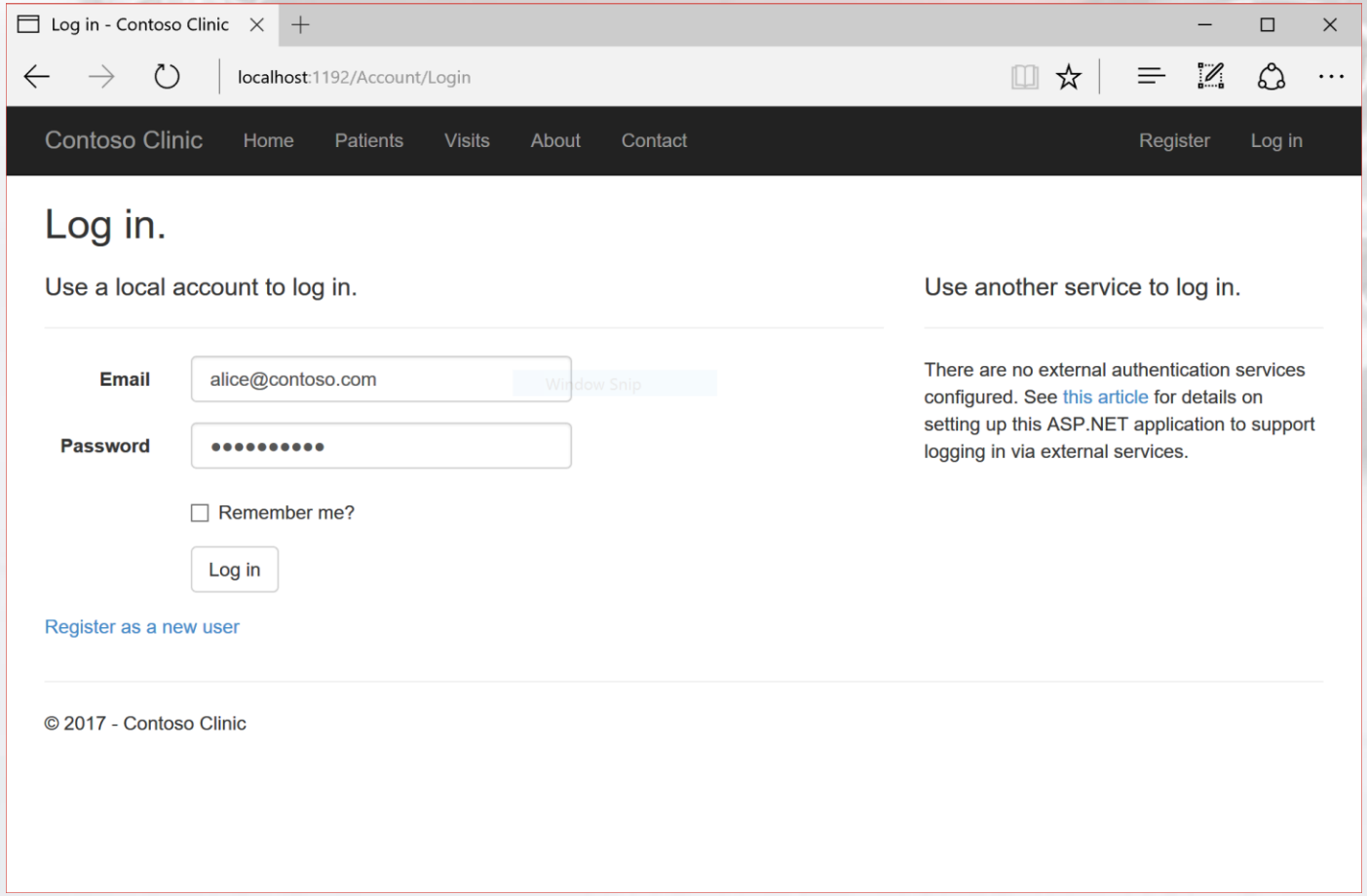
- Mascheramento
  - Real-time
  - Diversi tipi di maschere
  - Mascheratura parziale
- Basato su regole/permessi
  - A livello di colonna
  - Permesso di «unmask»
- Configurazione Azure nel portale



DEMO

Dynamic Data Masking

DDM: Alice login



DDM: Alice patients

Index - Contoso Clinic

localhost:1192/Patients

Contoso Clinic Home Patients Visits About Contact Hello alice@contoso.com! Log off

Index

Create New

SSN	FirstName	LastName	MiddleName	StreetAddress	City	ZipCode	State	BirthDate	
795-73-9838	Catherine	Abel	R.	57251 Serene Blvd	Van Nuys	91411	CA	10/09/1996 00:00:00	Edit | Details | Delete
990-00-6818	Kim	Abercrombie		Tanger Factory	Branch	55056	MN	05/06/1967 00:00:00	Edit | Details | Delete
009-37-3952	Frances	Adams	B.	6900 Sisk Road	Modesto	95354	CA	26/12/2005 00:00:00	Edit | Details | Delete
708-44-3627	Jay	Adams		Blue Ridge Mall	Kansas City	64106	MS	28/12/2011 00:00:00	Edit | Details | Delete
447-62-6279	Robert	Ahlering	E.	6500 East Grant Road	Tucson	85701	AZ	01/12/1953 00:00:00	Edit | Details | Delete

© 2017 - Contoso Clinic

DDM: Alice patients’ data masked

Index - Contoso Clinic

localhost:1192/Patients

Contoso Clinic Home Patients Visits About Contact Hello alice@contoso.com! Log off

Index

Create New

SSN	FirstName	LastName	MiddleName	StreetAddress	City	ZipCode	State	BirthDate	
795-73-9838	Catherine	Axxxx	xxxx	xxxx	Van Nuys	xxxx	CA	10/09/1996 00:00:00	Edit | Details | Delete
990-00-6818	Kim	Axxxx	xxxx	xxxx	Branch	xxxx	MN	05/06/1967 00:00:00	Edit | Details | Delete
009-37-3952	Frances	Axxxx	xxxx	xxxx	Modesto	xxxx	CA	26/12/2005 00:00:00	Edit | Details | Delete
708-44-3627	Jay	Axxxx	xxxx	xxxx	Kansas City	xxxx	MS	28/12/2011 00:00:00	Edit | Details | Delete
447-62-6279	Robert	Axxxx	xxxx	xxxx	Tucson	xxxx	AZ	01/12/1953 00:00:00	Edit | Details | Delete

© 2017 - Contoso Clinic

Funzioni Dynamic Data Masking

- Default
  - Dipendente dal tipo ‘X’, 0, 01.01.1900 00:00:00.0000000
- Email
  - aXXX@XXXX.com
- Random
  - Intervallo di interi
- Stringa Custom
  - Prefix length, [padding char], suffix length

Permessi Dynamic Data Masking

- CRATE e ALTER tabella
- ALTER ANY MASK (con ALTER per la tabella)
- UNMASK
- Può comunque aggiornare i dati!

Dynamic Data Masking Gotchas

- Attenzione allo spostamento di dati
  - Export/Import
  - SELECT…INTO
  - INSERT…SELECT…FROM
- Tecniche di forza bruta
  - Inferenza di valori (tramite predicati su intervalli)
  - Tabelle con valori di dominio

Limitazione Dynamic Data Masking

- Tipi colonna non ammessi
  - Colonne crittografate (Always Encrypted)
  - FILESTREAM
  - COLUMN_SET (o «sparse column» che ne fanno parte)
  - Colonne calcolate (però possono referenziare mascherate)
  - Colonne chiave indici FULLTEXT
- READTEXT, UPDATETEXT, WRITETEXT
  - Non funzionano correttamente con UNMASK

Report e revisione

Mettere in sicurezza ambienti SQL Server

Cosa tracciare

- Accessi
  - SQL Server Trace (Profiler, deprecato)
  - SQL Server Audit
- Dati modificati (versioni precedenti)
  - Change Data Capture
  - Temporal Databases

SQL Server Audit

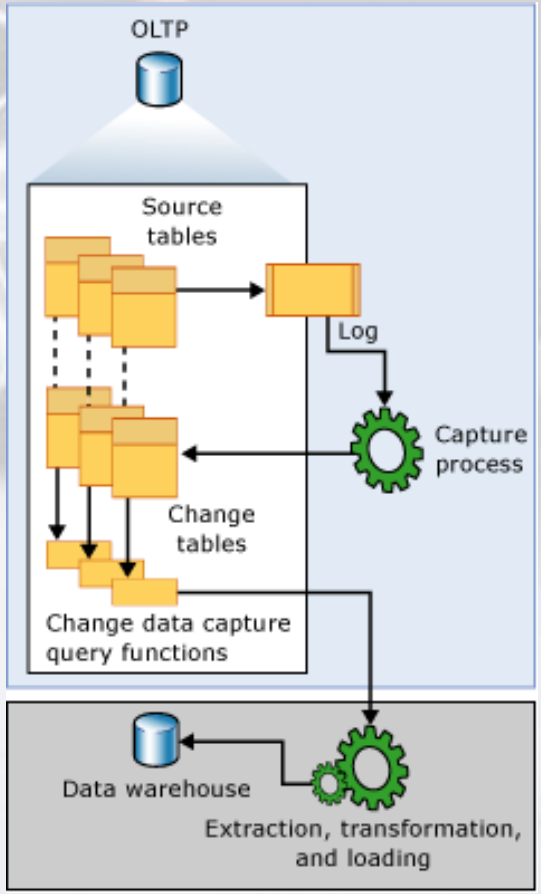
- Definizione gruppi di azioni da tracciare
  - Server
  - Database
- Target
  - File
  - Windows Log
- Disponibile con tutte le edizioni
  - a partire da SQL Server 2016 Service Pack 1
  - Implementazione diversa per Azure SQL Database

Policy Based Management

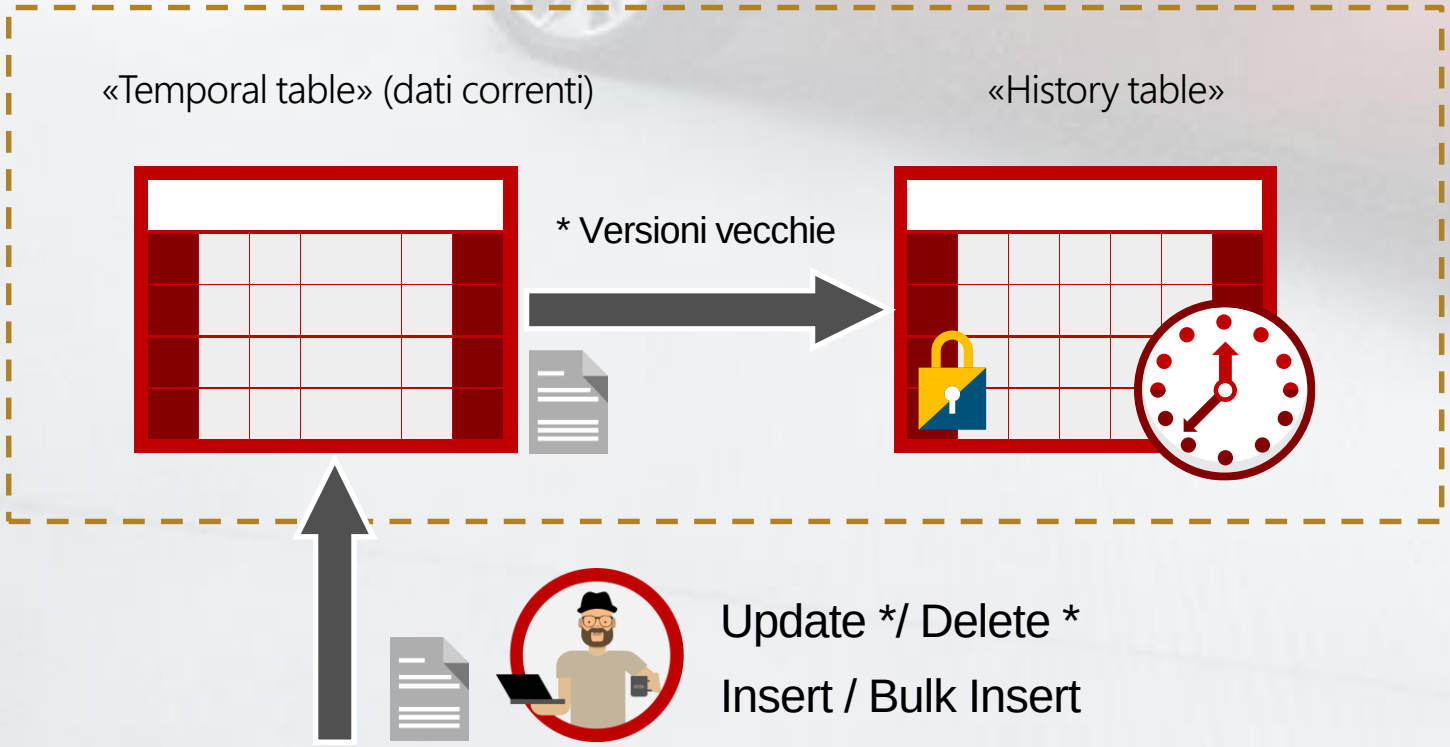
- Infrastruttura per
  - Definizione «policy»
  - Controllo conformità installazione con «policy»
- Serie di «policy» conformi a Best Practice
  - Categoria di policy per sicurezza!
- Enterprise Policy Management Framework
  - http://aka.ms/epmframework

Change Data Capture

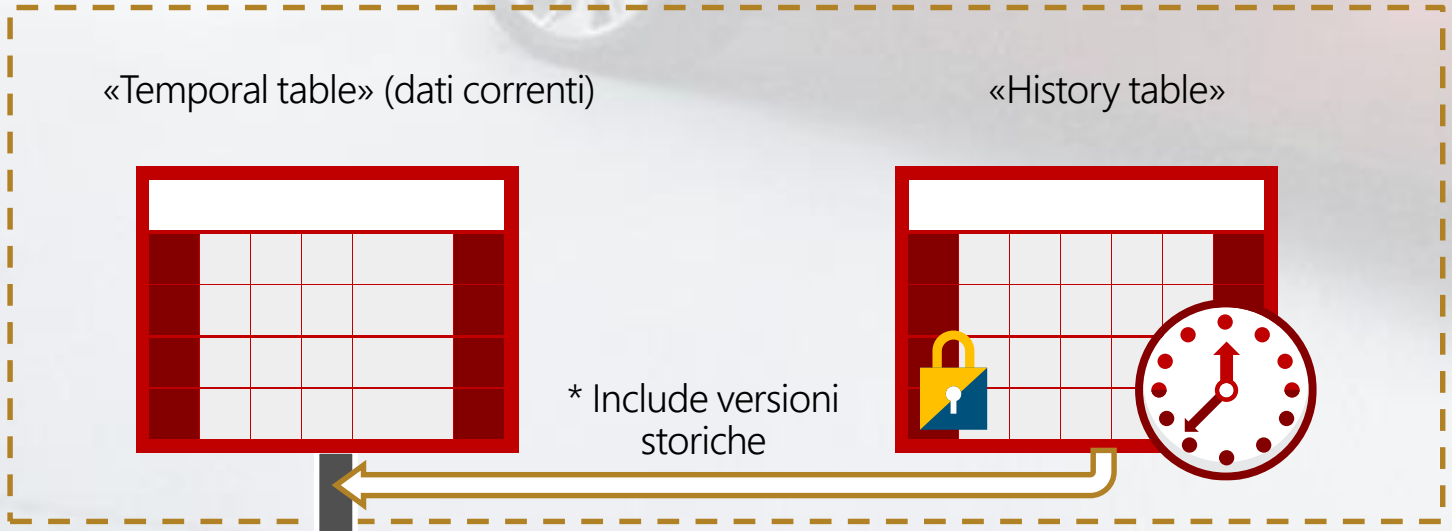
- Soluzione tradizionale Audit modifiche dati?
  - Trigger! Ma…
  - …complessità, prestazioni… ☹
- CDC cattura automaticamente modifiche
  - Pensato principalmente per caricare DWH
  - Genericamente va bene per tenere storico modifiche



Modifiche Database Temporali



Interrogazioni Database Temporali



Query normali
(dati correnti)

Query temporali *
FOR SYSTEM_TIME
ALL, AS OF,
BETWEEN … AND …, FROM … TO,
CONTAINED IN

Azure SQL Database Threat Detection

- Semplice opzione da attivare per database
  - Richiede attivazione «SQL Database Auditing»
- Rileva potenziali minacce/vulnerabilità
  - Attacchi di tipo «SQL Injection»
  - Accessi anomali (es. da luoghi anomali)
- Allarmi
  - In tempo reale
  - Raccomandazioni cosa investigare/come mitigare/rimediare

DEMO

Vulnerability Assessment

Q&A